# Secure User Authentication Scheme Using Multimodal Biometrics

Aditi Rajput, Gaurav Varshney

Department of Computer Science Engineering
Indian Institute of Technology, Jammu

Abstract

Authentication is the process of verifying identity. Authentication comprises two steps: Identification and Verification. During identification, users provide information about themselves. In verification, the information the user provides is validated to determine whether the user is legitimate. Over the past decade, the increase in security breaches manifests the security problems associated with authentication involving a single factor, such as password/PIN. Despite being more secure and strongly promoted, two-factor(2FA) or multi-factor (MFA) schemes fail to protect against recent phishing threats such as real-time MITM, control relay MITM, malicious browser-extension-based phishing attacks, and various other attacks and require users to purchase and carry other hardware (security keys or tokens) for additional account protection. Biometrics was adopted in later stages to enhance security and privacy. However, ~~single-modal~~unimodal biometrics ~~have some limitations~~are limited by sensor noise, restricted distinctiveness, non-universality and spoofing, and ~~multimodal biometric systems require separate hardware devices to capture individual biometric samples, which incurs extra costs and more time to deploy the solution~~conventional multimodal systems acquire each trait sequentially through a dedicated sensor, which raises deployment cost and enrolment latency. In addition, it also affects the user experience, giving rise to less usability. Therefore, a more secure and user-friendly authentication scheme is required. In this paper, an authentication scheme based on multimodal biometrics is proposed. ~~The proposed authentication system uses Face, Voice, and CAPTCHA fetched from a real-time recorded video. This improves the user experience and security compared to other multimodal biometric schemes, where the login credentials are fetched individually.~~The proposed system derives three independent authentication factors—face, voice and a spoken dynamic CAPTCHA—from a single real-time video stream, so that all modalities are acquired in parallel from one commodity sensor rather than individually. The three factor-level decisions are combined by an AND-based decision-level fusion rule, so that authentication succeeds only when every factor is verified. Because the CAPTCHA is server-generated and freshly issued per session, the spoken challenge simultaneously serves as a liveness cue and as a session-binding nonce, which raises the cost of replay and phishing-relay attacks. The design improves usability and deployability relative to multimodal schemes that acquire each credential separately, without requiring dedicated biometric hardware. No recording of any user is retained: each enrolment is reduced to encrypted biometric templates and the recording is destroyed, so a compromise of the enrolment store yields no replayable biometric media. Measured on a genuine login, concurrent evaluation of the three factors reduces authentication latency by approximately 2.0 seconds relative to a cascaded evaluation of the same factors.

Keywords— Authentication, Identity, Passwords, Biometrics, 2FA, MFA, Multimodal biometrics

## 1 Introduction

### 1.1 Authentication

Authentication is verifying identity to provide access to the system or resources. Digital identity is proof that users provide to the system to prove they are the ones they claim to be. Identity can be either a weak identity or a strong identity. A strong identity is difficult to spoof because identity is the verifier itself. An example is biometrics, in which biometric identity is the verifier. The verifier is considered a strong verifier. There is no separate requirement for a verifier, making it difficult to be spoofed. Whereas in weak identity, there is a requirement for a verifier, making it susceptible to spoofing. An example can be a username, which requires a password as a verifier. Here, the verifier is considered a weak verifier. These credentials are subject to attacks like theft, password guessing, etc. and can be easily compromised. In user authentication, the user proves to the authority that they are the one who they claim to be.

As the world becomes increasingly digitalized, services are more susceptible to cyber-attacks. With more than five billion internet users worldwide[1], authentication is a must to protect their data from cyberattacks. So, there is a vital need for authentication mechanisms which are secure and robust. Authentication is required everywhere. Authentication can be done between (i) User to User, (ii) Device to Device, and (iii) User to Device.

1) User to User: In user-to-user authentication, one person provides his identity to the other person, and the other person will act as a verifier to decide whether that user will be given access to the resources.
2) Device to Device: In device-to-device authentication, two devices are authenticating each other. This type of authentication is most commonly used in smart vehicles and IoT devices, where devices act as identifiers and verifiers. The rapid development of the Internet of Things (IoT) and edge computing platforms has increased the importance of device-to-device (d2d) authentication. [2]

design a D2D continuous authentication protocol that utilizes devices' features (i.e., battery capacity, location, token) to continuously verify devices during the session.

3) User to Device: In user-to-device authentication, the user provides their credentials as identity. ~~The.~~ The device will verify and decide whether the user is authorized to access the resources. This is the most commonly used authentication. In this type of authentication, users can use passwords, OTP, fingerprints and a combination of factors to authenticate themselves to access the resources.

The scope of this paper is limited to user-to-device authentication. Authentication can be done either online or offline. According to the World Bank, only about 50% of people in low and middle-income countries have access to the internet (compared to more than 70% of the population in upper-middle-income countries and 89% of people in high-income countries). Globally, Kepios' research suggests that around four in 10 people are not online [3]. In online authentication, users must be connected to the internet to achieve authentication. This is the conventional method of authentication which is most commonly used.

Authentication factor is used to authenticate individuals. An authentication factor is a distinct security credential employed to authenticate and authorize a user seeking entry, sending messages, or soliciting data from a protected network, system, or application. The most basic authentication mechanism is username and password. There are three authentication factors which are widely used for authentication:
(i) Knowledge-factor
(ii) Possession-factor
(iii) Inherence-factor

1) Knowledge-factor: Knowledge-factor refers to those metrics or factors the user knows. These are those factors the user can remember and use the user's knowledge; that is why given name knowledge-factor. Examples of this factor include text passwords and graphical passwords.
2) Possession factor: Possession factor refers to those factors which the user owns or presents with the user, such as a smart card or mobile phone. These factors are those factors which can be physically seen and held. These factors have the disadvantage of being stolen.
3) Inherence factor: Inherence factor refers to those personal factors inherited by the user and cannot be taken away from the user. These factors uniquely identify each individual and cannot be the same for two persons. Examples include fingerprint, iris, retina, ECG etc.

Apart from these three factors, there can be other factors like geographic location, IP address, behaviour factors, etc. But those, as mentioned earlier, three are the most commonly categorized.

Figure 1 shows an authentication scenario using any of the three authentication factors. The steps followed by a user to perform authentication are described as follows:

1) User requests for a particular resource. This resource can be a website, social media account, or digital payment service.
2) This resource access is provided only after submitting specific credentials. These credentials can be either of the three authentication factors discussed above or a combination. So, the website asks for an authentication factor.
3) User submits required authentication factor to the website.
4) Website sends the presented credential to the authentication server for verification.
5) The Authentication server performs the necessary checks to complete the verification. If verification is successful, the website is given a successful verification message.
6) Website then provides the user with access to the requested resource.

### 1.2 Cataloguing of Authentication schemes

Various authentication schemes have been proposed so far. In the beginning, authentication systems mainly relied on single-factor authentication schemes. The most commonly used single-factor authentication approach is username and password. But passwords are the weakest security mechanisms. The personal data of 815 million Indians exfiltrated from the ICMR's Covid-testing database has been leaked on the dark web in October 2023 [4]. The weakness linked to using passwords as an authentication mechanism leads to the adoption of two-factor authentication (2FA) and multi-factor authentication (MFA) schemes. But people often get confused between 2FA and MFA. Although 2FA and MFA involve using more than one factor for authentication, the two have significant differences. 2FA uses two factors for authentication. For example, the password plus OTP sent through SMS or email is 2FA. At the same time, MFA consists of using two or more independent authentication factors. The two factors should be from different categories. For example, a password plus biometric sample (e.g. Iris ) is MFA, but a password in combination with OTP cannot be regarded as MFA. Velasquez, Cora and Rodreguez have found 515 single-factor and 442 multi-factor authentication techniques in their research.[5]
A broad classification of various authentication schemes is shown in figure 2. The schemes of authentication are mainly categorized as Single-factor authentication,two-factor authentication(2FA) and multi-factor authentication(MFA).

#### 1.2.1 Single factor authentication

In single-factor authentication, the user uses only one metric for authentication. This metric can either be a knowledge factor (for example, passwords), a possession factor (for example, smart card) or an inherence factor (for example, fingerprint, iris scan, voice, gait, etc.). These are further divided into three types:

1) Knowledge-factor based
   This includes single-factor authentication involving only knowledge factors like passwords, PIN, etc. This is further divided into two categories based on the secret used:
   a) Text-based secret
      This includes those secrets written in text formats like Password and PIN by using alphanumeric characters. The problem with text-based secrets is that users keep the same password for different accounts, which poses

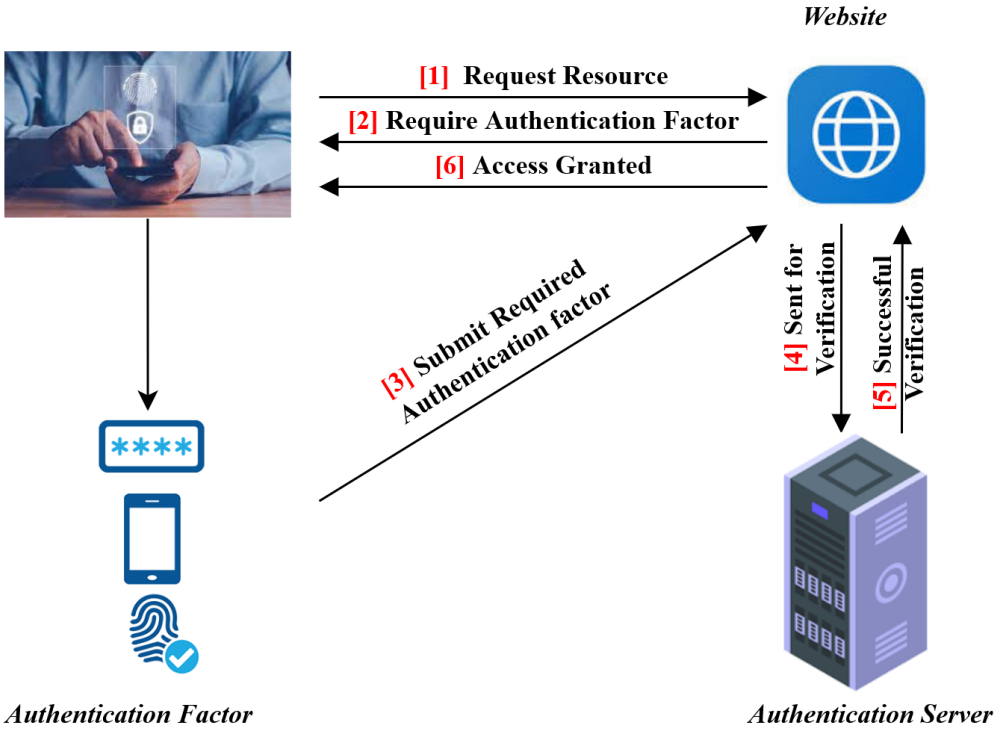



Fig. 1: Authentication Scenario

a severe security threat such that if one account is compromised, all other accounts are also at risk.

b) Graphical-based secret
Graphical-based secrets solve the problem associated with text-based secrets by selecting a set of images from the images displayed on the screen and then selecting those images at the time of authentication. It is further categorized into two types:

i) Recognition-based Graphical password
In this authentication scheme, the user must select specific images that they have chosen at registration. One example is Passface [6], in which the user has to determine four face images from a database of faces as their password.

ii) Recall-based Graphical password
In this authentication scheme, the user has to produce the drawing again that they have drawn at the time of registration. An example of this technique is Passpoint [7], where a user can select any location on an image to create a password. A tolerance range is calculated around each selected pixel. To authenticate, the user must click within the tolerance range of their chosen pixels, following the same order.

2) Ownership-factor based
This includes single-factor authentication involving only ownership factors like Smart cards, hardware tokens, mobile phones, OTP, etc.

3) Inheritance-factor based
This includes single-factor authentication involving only inherence factors like fingerprint, face, iris, retina, gait, hand geometry, etc. This is further divided into two categories:

a) Physiological Biometrics
These biometrics include the physical characteristics of an individual. These characteristics are inherent to a person and cannot be changed. Examples are fingerprint, palmprint, Hand geometry, face, iris, retina, ECG, EEG, etc.

b) Behavioral Biometrics
These biometrics include human behaviour and how a person performs a particular action. These are subject to environmental changes. Examples are tapping behaviour, finger gestures, hand gestures, voice, gait, etc.

### 1.2.2 Two factor authentication

In two-factor authentication, the user uses two metrics for authentication. In addition to one factor, the second factor provides an extra layer of security. The two metrics can be a combination of knowledge and possession factor, knowledge and inherence factor or inherence and possession factor. Two-factor authentication (2FA) enhances security and is designed to protect the user's confidential information from unauthorized users. Passwords are unsafe means of authentication; 2FA requires an additional form of identification to prove you are who you claim to be. The two factors typically used for authentication are something you know (such as a password or PIN) and something you have (such as a mobile device or security token). There is another factor, something you are (Biometrics), which is also included to further enhance the security owing to its advantage over the other two factors. By requiring both factors, 2FA significantly increases the difficulty of someone

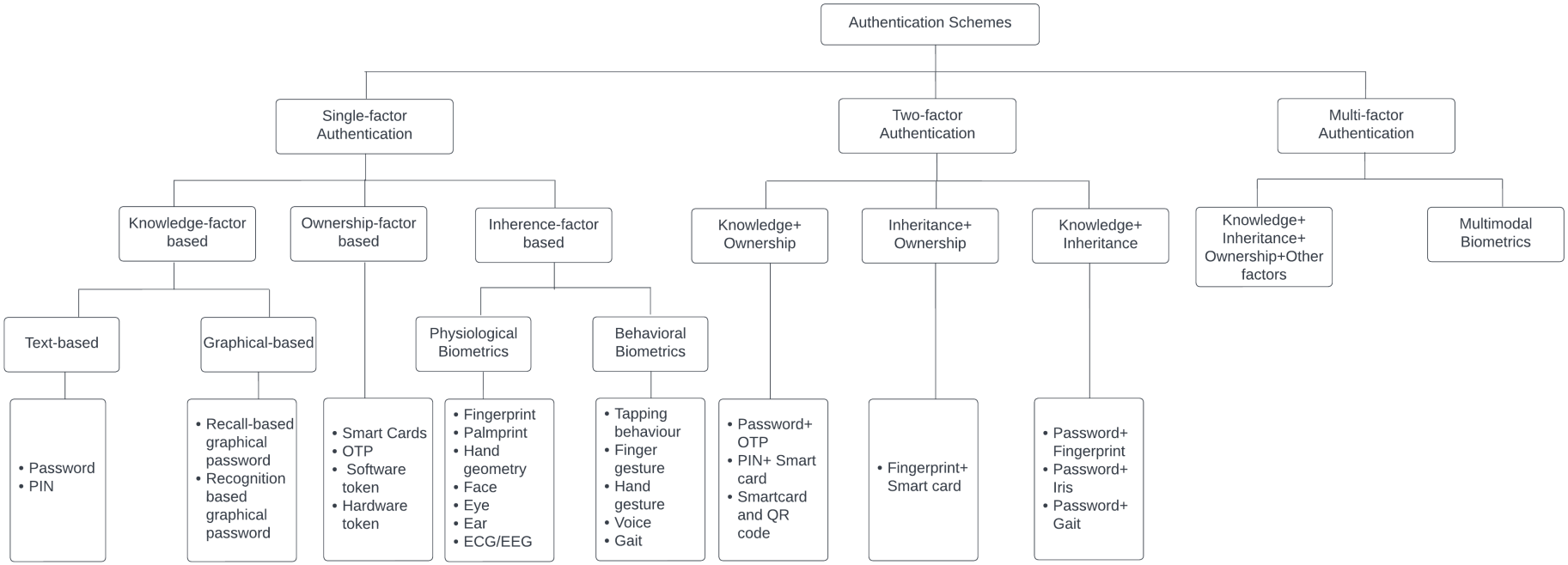



Fig. 2: Cataloguing of Authentication Schemes

gaining unauthorized access to your account. There are several reasons why 2FA is required. Some of these are stated below:

1) Passwords can be easily compromised: Passwords are a weak form of authentication because they can be easily guessed, stolen or hacked. 2FA provides extra security to protect the system even if a password has been compromised.
2) Protection against phishing attacks: Phishing attacks are when attackers attempt to trick you into providing your login credentials or other sensitive information. With 2FA, even if an attacker can access the password, they cannot get access until they have a second factor.
3) Compliance: Many regulations and standards require organizations to implement 2FA to protect sensitive information and prevent unauthorized access.

Generally, 2FA is an effective way to meet security needs and protect confidential data. Two factors used in 2FA can be from any of the authentication categories. [8] proposed a 2FA that uses password and OTP. [9] uses smart cards and QR codes as two factors in their authentication scheme. ATMs also employ 2FA by using PINs and smart cards. All these 2FA schemes discussed involve knowledge and ownership factors. Some schemes have also been proposed in the literature that involve a combination of inherence and ownership factors. [10] proposes a scheme that uses fingerprints and smart cards for authentication. There are certain schemes in which knowledge and inheritance factors are combined to verify the identity. Examples include schemes proposed by [11] that use password and fingerprint and by [12] that use PIN and iris.

### 1.2.3 Multi factor authentication

With the advancement in technology, passwords alone are insufficient to verify identity. Although 2FA adds a second factor to the conventional authentication method, there is no standard for selecting a second factor. The second factor chosen might be attack-prone and can be compromised easily. So, we need to move towards a more secure authentication mode involving two or more authentication factors with the restriction that the factors used should be independent. Multi-factor authentication is shown in figure 3. In Multi-factor authentication (MFA), users need to provide multiple forms of identity to access a system or application. MFA is becoming increasingly important today, where security breaches and identity theft are more common. In multi-factor authentication(MFA), all three factors, viz. knowledge, possession and inherence, can be combined for authentication. Multiple layers of information are added to a single factor, like a password for authentication. The purpose of MFA is to make the authentication process difficult for illegitimate users. MFA allows users to access accounts or systems by providing at least two different forms of identity. This includes:

- What the user knows. e.g. Password or PIN code
- what the user has. e.g. mobile phone or token device
- what the user is, e.g. biometric factors such as fingerprint or facial recognition

MFA is commonly used in online banking, email, social media, and other applications where security is of utmost importance. It is a simple and effective way to enhance the security and protection of any system. For example, the user must submit an OTP and provide their fingerprint scan in addition to the password. Various multi-factor authentication schemes have been proposed in the literature.

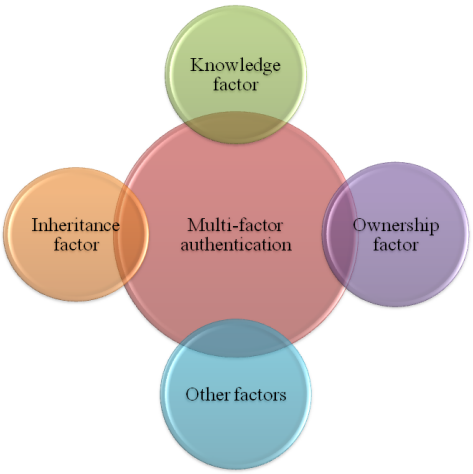



Fig. 3: Multi-factor Authentication

Lee et al. [13] introduced an authentication scheme that leverages smart card and fingerprint verification, improving security and reliability. The fingerprint verification relies on minutiae extraction and matching, while the scheme is based on ElGamal's public key cryptography using two secret keys. Scaria and Mengalingm [14] proposed a multi-factor authentication scheme which comprises three factors - OTP, Fingerprint and noisy password. In this method, a noisy password includes a genuine password concealed within the noise, which only authorized users are aware of. Abdurrahman et al. [15] introduced a multi-factor authentication method called PGT, which is an acronym for pre-shared number, GPS location, and time stamp. This method is designed to boost the security of web accounts by creating a confidential hash code that incorporates the user's current GPS location and a pre-shared number.

### 1.2.4 Biometric Authentication

Conventional methods of authentication generally involve one or both knowledge and possession factors. However, the problems associated with these factors led to the evolution of biometric authentication. Biometric authentication uses physiological or behavioural traits of human beings to verify identity and authenticate to the system. This type of authentication offers certain advantages over traditional methods. This prevents imposters from attacking the system, as these traits are unique to each individual and cannot be forged. This also provides passwordless authentication, thereby lowering dependence on passwords. However, most systems using biometrics as authentication only employ single biometrics. Using a single biometric factor potentially lowers the authentication system's accuracy rate due to poor data quality, the overlap between identities and limited resources to uniquely identify a person. Unimodal biometrics suffer from the disadvantages mentioned below-

1) Noise: The noise in sensed data can be attributed to defective or poorly maintained sensors, such as a fingerprint sensor that has accumulated dirt, resulting in deformed and noisy data. Additionally, environmental factors such as cold temperatures can affect voice recognition, while wearing glasses can alter iris recognition performance and variations in lighting conditions can impact facial recognition.
2) Distinctiveness: Another challenge in biometric recognition is distinctiveness, which involves the significant variation of a biometric trait across individuals. Intra-class divergences occur when a user interacts with the sensor incorrectly or exhibits an incorrect facial pose. At the same time, inter-class similarities may be present due to overlaps in the feature sets of multiple users.
3) Non-universality: Non-universality is another issue when the biometric system cannot acquire meaningful data from a particular group of users. For instance, scars or cuts on fingerprints may affect the accuracy of a fingerprint-based biometric system, leading to incorrect minutiae feature extraction. Faulty user-sensor interaction can also result in undesired matching results.
4) Spoofing: Spoof attacks are another challenge wherein an imposter person attempts to spoof the biometric system using fake biometric traits or data from an authorized user. For example, by using artificial fingers or fingerprints.

These problems result in higher false acceptance rates (FAR) and false rejection rates (FRR). Multimodal biometrics has emerged as a solution to some of the issues in unimodal biometrics, offering benefits such as enhanced recognition accuracy, privacy, and improved biometric data enrollment. In this, multiple biometrics features are combined for authentication and are called multimodal biometrics.

### 1.3 Research problem and motivation

Researchers are trying to find a more secure and robust authentication mechanism to combat security threats and prevent the system from cyber-attacks. Single-factor authentication cannot be a secure authentication method because the password is the main factor used for authentication, and passwords are unsafe and subject to various attacks like guessing and brute-force attacks. Passwords provide the weakest links for the attacker to access the system. MFA and passwordless authentication is gaining popularity and becoming the current trend. In the previous subsection, the benefits of biometric authentication are discussed and how multimodal biometric authentication can be a viable solution. Multimodal biometrics, which involves more than one biometric trait, is a secure and effective authentication mode. All the schemes based on multimodal biometrics involve some problems like

- interacting with different devices to provide biometric identity
- The extra cost involved in purchasing devices

So, ~~there was no scheme which allowed parallel acquisition of biometrics~~existing multimodal schemes typically acquire each trait through a dedicated sensor and rarely bind acquisition to a per-session challenge; the proposed scheme instead combines parallel acquisition of biometrics from a single commodity sensor with binding of that acquisition to a fresh server-issued challenge.

### 1.4 Threat Model

We consider an adversary whose goal is to authenticate as a legitimate user to the verifier. The adversary is assumed to (i) observe and record public or previously transmitted media of the victim, including video captured in earlier sessions, (ii) mount phishing and real-time relay attacks in which a fraudulent site forwards credentials to the genuine verifier, and (iii) attempt presentation attacks by replaying a pre-recorded video of the victim. The verifier and the server-side challenge generator are assumed to be honest; the client device and the network path between the client and the verifier are untrusted. Attacks that require compromising the verifier itself, coercing the enrolled user, or synthesising a real-time deepfake that reproduces an unpredictable challenge within the session window are outside the scope of this work, as is a real-time relay that forwards the live challenge to the victim and returns the response within its validity window. Under this model, the security argument of the proposed scheme rests on two properties: the challenge is unpredictable and single-use, so a recorded response is not accepted in a later session; and the AND-based fusion rule requires every factor to be verified, so compromise of any single modality is insufficient for a successful login.

### 1.5 Major Contributions

The proposed scheme provides a secure and higher user acceptability multimodal biometric authentication system, unlike other multimodal biometric-based authentication systems requiring interaction with separate devices or sensors. This scheme involves parallel acquisition of biometric samples, increasing usability, security and deployability. The scheme is entirely passwordless and cost-effective due to no requirement for sensors or separate physical devices to acquire biometric samples. ~~The use of dynamic CAPTCHA reduces video reuse/replay attacks. No prerecorded video can be used because of the availability of this feature. Dynamic CAPTCHA also adds toward the liveliness detection of a specific user because the user will speak the captcha while recording real-time video. This scheme also prevents phishing attacks due to the presence of a captcha because the CAPTCHA is dynamic, and AND rules are implied. So, CAPTCHA validation will fail in case of a phishing attack, thereby preventing unauthorized login.~~The dynamic CAPTCHA acts as a per-session nonce: because the challenge is generated server-side and is unpredictable to the adversary, a previously recorded video cannot satisfy the current challenge, which mitigates video reuse and replay attacks. Since the user must utter the challenge during acquisition, the spoken CAPTCHA additionally provides a challenge–response liveness cue that is bound to the same video stream from which the face and voice evidence is derived. The same mechanism raises the cost of phishing, though its limits should be stated precisely. A phishing site that harvests a recording and replays it later fails, because the challenge it was made against has already been consumed and a fresh one is unpredictable. A real-time relay that forwards the genuine verifier's live challenge to the victim and returns the victim's

fresh recording within the validity window is not prevented by this mechanism alone; defending against that case requires binding the challenge to the origin, which the present design does not do. Two further contributions concern what the verifier stores and how the factors are combined. First, the scheme retains no biometric recording: enrolment reduces the recording to encrypted templates and destroys it, so the enrolment store holds no replayable media, and the stored artefact is roughly two orders of magnitude smaller than the recording it replaces. Second, the three factors are evaluated concurrently rather than as a cascade, which both removes a timing side channel that would otherwise reveal which factor failed and reduces measured authentication latency. The rest of this paper is organized as follows. The related literature survey is discussed in section 2. The working of the proposed multimodal biometric authentication system is introduced in section 3. Implementation and analysis of the proposed multimodal authentication system are demonstrated in section 4. At last, this paper is concluded by section 5.

## 2 Related Work

Marasco and Albanese [16] suggested a multi-factor authentication approach called FingerPIN, which combines knowledge and inherence factors with a fingerprint-based personal identification number(PIN). The improved version of the FingerPIN scheme [17] strengthens the security of this scheme and makes it more user-friendly. Li and Hwang [18] proposed a remote user authentication scheme based on biometrics which uses smart cards and relies on biometric verification, a one-way hash function, and smart card technology. Das [19] improved the work of Li et al. and proposed a new scheme in 2011. Das's scheme does not provide resistance against the offline password guessing attack or the privileged insider attack and does not provide user anonymity. To address the limitations in Das's scheme, Lee and Hsu [20] introduced an alternative approach that employs extended chaotic maps.

D. Jagadiswary and D. Saraswady [21] proposed a scheme that combines the RSA asymmetric cryptographic algorithm with biometric traits like fingerprints, retina scans, and finger vein patterns. Puneet Gupta et al. [6] devised a precise authentication system that utilizes finger vein technology to elevate the quality standards of vein images and mitigate noise data during extraction. Das et al. introduced a finger-vein-based Biometric Identification System that uses a Convolutional Neural Network (CNN) [8]. Still, it does not provide robust security for complex databases, particularly in cross-matching scenarios.

M. Hammad et al. [22] propose two multimodal authentication systems (sequential and parallel) and use a combination of ECG and Fingerprint. They apply Convolution Neural Network (CNN) and Q-Gaussian multi-support vector machine (QG-MSVM). Using two datasets, they attained an EER of 0.14% and 0.10% for the sequential systems. The parallel system achieves an EER of 0.40% and 0.32% for respective datasets.

Kim and Hong [23] propose a multimodal biometric authentication approach using teeth image and voice as biometric features. The individual matching scores obtained from the teeth image and voice are combined using a weighted summation operation, and the fused score is used to decide the acceptance or rejection. The proposed method produces results with an EER of 2.13%.

Ahamed et al. [24] propose an AI-based multimodal biometric authentication model for device-level authentication that involves ECG (Electrocardiogram) and PPG (Photoplethysmography) signals. This authentication model provides results with 99.8% accuracy and an Equal Error Rate (EER) of 0.16.

[25] propose a scheme that combines fingerprint, face, and iris biometrics based on matching scores. The SVM classifier, the sparse SVM classifier, and the rough set fuzzy classifier are used for fusion and classification purposes.

Multimodal schemes proposed so far offer less usability experience and could be more cost-effective. Because user needs to submit multiple biometric samples separately, and their acquisition requires costly hardware devices or sensors. So, we design an authentication scheme that offers parallel acquisition of biometric samples and does not require expensive hardware devices or sensors. Our scheme also provides resistance to phishing attacks.

### 2.1 Comparison with Recent Authentication Systems (2020–2026)

This work is an authentication system, so the comparison below is restricted to recent work that explicitly presents a biometric authentication (verification) procedure. Tables 1 and 2 compare the proposed scheme with five such systems published between 2024 and 2026 [26]–[30]. Work whose primary contribution is biometric recognition [31], an audio-visual recognition and presentation-attack survey [32], a cross-modal attack on voice authentication [33], or biometric template-protection methods [34], [35] is cited as supporting security literature but is not treated as a directly comparable authentication system, because those works do not themselves deploy an end-to-end authentication decision. The comparison is not a claim that the five systems fail to authenticate; each does. It identifies what each authenticates and how, and how the present architecture differs. Cells marked NR (not reported) denote a property the cited work does not discuss; ✓ is used only where the property is explicitly supported and ✗ only where it is explicitly absent or placed out of scope. A security property is never inferred from a paper's title or from a related property: biometric matching is not read as liveness, encryption is not read as unlinkability, liveness is not read as replay protection, and a dynamic challenge is not read as complete relay protection.

Positioning. Prior work demonstrates that multimodal biometric authentication, liveness detection, challenge-response authentication and biometric template protection have each been investigated. The proposed scheme does not claim novelty for these individual components in isolation. Its contribution is their integration into a single deployed authentication architecture combining face verification, speaker verification and a fresh spoken challenge, with concurrent factor evaluation, decision-level conjunctive fusion, template-only storage, authenticated encryption, pseudonymous template naming, enrolment binding and explicit challenge lifecycle controls. Table 2 shows that no single prior authentication system in the comparison combines a session-bound spoken challenge with protected, pseudonymous template storage and

TABLE 1: Authentication Architecture Comparison (recent authentication systems, 2024–2026). All five prior works present an explicit authentication/verification procedure. NR = not reported by the cited work.

| Work + Link | Year | Explicit Auth? | Modalities | Auth. Structure | Fusion / Decision | Liveness / Challenge | Replay Prot. | Phishing / MITM / Relay | Main Security Mechanism | Evaluation |
|---|---|---|---|---|---|---|---|---|---|---|
| Jha et al. [2024] | 2024 | Yes | Face + Speech | Simultaneous (single decision) | Feature-level fusion | Texture + synchronized-speech liveness; no dynamic challenge | NR | NR | Liveness detection (feature fusion) | Recognition accuracy |
| Aanjankumar et al. [2025] | 2025 | Yes | Face (single trait) | Single-modal (two-network) | Feature/architecture fusion | Anti-spoof / PAD (3D mask); no dynamic challenge | Via signatures (network) | MITM/replay via Ed25519 signatures | ElGamal + AES-256; Ed25519 signatures | Acc. 97.1%; EER 3.2% |
| Jha et al. [2025] | 2025 | Yes | Face + Speech | Simultaneous (single decision) | Feature-level fusion; Bi-LSTM-DCNN ensemble | Liveness via eye-blink (EAR); no dynamic challenge | NR | NR | Liveness detection (eye blink) | Acc. 98.2%; EER 3.23% |
| Chen et al. [2026] | 2026 | Yes | Face + Voice | Sequential two-step (face then voice) | Cascade (face gates voice) | NR | NR | NR | Two-step cascade | Face acc. 95.1%; voice EER 3.46% |
| Jha et al. [2025], challenge-response | 2025 | Yes | Face + Speech (spoken random word) | Challenge-response, then verify | Feature-level fusion; CNN-BiLSTM | Challenge-response liveness; random word, server-delivered, session expires on failure | ✓ (counters replay video via challenge) | NR | Challenge-response liveness + PAD | Acc. 96.81%; EER 3.37%; spoof-video eval |
| Proposed Secure User Authentication Scheme | 2026 | Yes | Face + Voice + spoken dynamic CAPTCHA | Concurrent three-factor (parallel) | Decision-level AND ($D{=}b_f{\wedge}b_a{\wedge}b_c$); server-side | Challenge-response liveness cue (not full PAD); dynamic 5-digit CAPTCHA: server-generated, single-use, id-bound, 5-min expiry, spoken | ✓ (previously recorded video/challenge) | Mitigates replay-based phishing; real-time relay ✗ (out of scope) | AES-256-GCM templates; HMAC-pseudonymous names; encrypted account PII with HMAC email index; keys separated by security domain (signing / template / PII) and enforced at production startup; server-signed enrolment token; server-side decision | Functional end-to-end; latency; diagnostic scores; ~~no FAR/FRR/EER (corpus too small)~~CREMA-D, controlled single session: voice EER 3.15%; fused FAR 0 observed, FRR 6.13% at deployed thresholds |

TABLE 2: Security Mechanism Comparison (recent authentication systems, 2024–2026). ✓ = explicitly supported; ✗ = explicitly absent / out of scope; NR = not reported (the work is silent). Proposed-scheme notes: liveness is a challenge-response cue, not a complete presentation-attack detector; replay protection covers a previously recorded video/challenge, not all replay; phishing mitigation covers replay-based phishing only; relay and deepfake are ✗ because the threat model of Section 3.1 places sophisticated real-time relay and real-time challenge-reproducing deepfakes out of scope; unlinkability is claimed for the biometric template store only, not the account database; raw media retention ✗ means no permanent recording is kept.

| Work + Link | Live-ness / PAD | Replay Prot. | Dyn. Chall. | Phish / MITM | Relay | Deep-fake | Templ. Prot. | Encr. | Unlink./ Pseud. | Raw media ret. | Server dec. |
|---|---|---|---|---|---|---|---|---|---|---|---|
| Jha et al. [2024] | ✓ | NR | NR | NR | NR | NR | NR | NR | NR | NR | NR |
| Aanjankumar et al. [2025] | ✓ | ✓ | NR | ✓ | NR | NR | ✓ | ✓ | NR | NR | NR |
| Jha et al. [2025] | ✓ | NR | NR | NR | NR | NR | NR | NR | NR | NR | NR |
| Chen et al. [2026] | NR | NR | NR | NR | NR | NR | NR | NR | NR | NR | NR |
| Jha et al. [2025], challenge-response | ✓ | ✓ | ✓ | NR | NR | NR | NR | NR | NR | NR | ✓ |
| Proposed Scheme | ✓ | ✓ | ✓ | ✓ | ✗ | ✗ | ✓ | ✓ | ✓ | ✗ | ✓ |

a server-side conjunctive decision; the closest, a challenge-response multimodal system [30], shares the spoken challenge and liveness properties but does not report template protection, encryption, pseudonymous storage or enrolment binding, and fuses at the feature level rather than combining independent per-factor decisions.

The closest differences are as follows.

1) Compared with Jha et al. [2024] [26]: face + speech with texture/speech liveness, fused at the feature level; the present scheme adds a server-generated dynamic spoken challenge and a template-storage and enrolment-security architecture, and combines independent per-factor decisions rather than fused features.
2) Compared with Aanjankumar et al. [2025] [27]: a single-trait facial authentication system with strong cryptographic storage and signature-based transport protection; the present scheme is multimodal (face + voice + spoken challenge) and adds a challenge-response liveness cue and pseudonymous template naming, while not claiming the signature-based MITM property that work reports.
3) Compared with Jha et al. [2025] [28]: feature-level multimodal face/speech fusion with eye-blink liveness; the present scheme uses independent factor decisions combined by an AND rule at the decision level, and adds a session-bound challenge and protected storage.
4) Compared with Chen et al. [2026] [29]: a sequential two-step face-then-voice cascade; the present scheme evaluates face, voice and the spoken CAPTCHA concurrently and combines them conjunctively, which also removes the timing side channel of a cascade and returns an identical response whichever factor fails.
5) Compared with the challenge-response multimodal system Jha et al. [2025] [30]: both use a random spoken challenge for liveness; the present scheme's challenge is server-generated, single-use, identifier-bound and expiring, is integrated with face and speaker verification under decision-level AND fusion, and is paired with AES-256-GCM encrypted, HMAC-pseudonymously-named template-only storage and token-bound enrolment, none of which that work reports.

Evaluation scope. Among the compared systems, recognition-oriented accuracy, EER and related rates are reported by [26]–[30], and [30] additionally reports a spoof-video evaluation. ~~The present work does not report FAR, FRR or EER: its current corpus is too small for a meaningful error-rate claim (Section 4.5).~~The present work reports FAR, FRR and EER on the public CREMA-D corpus under controlled single-session studio conditions (Section 4.4); it does not report cross-session or cross-device error rates (Section 4.5). It ~~instead~~also reports diagnostic matcher score separation (Table 8), functional end-to-end authentication behaviour, and processing latency (Section 4.2), where concurrent evaluation overlaps the biometric and challenge branches and reduces mean end-to-end latency from 15,320 ms (cascaded) to 13,293 ms (concurrent), a reduction of approximately 2,027 ms (≈1.15×). Accuracy figures across these systems are measured on different datasets and protocols and are therefore not directly comparable, and no such cross-system accuracy claim is made here. Consistent with the threat model of Section 3.1, the scheme does not claim to defeat sophisticated real-time relay attacks or real-time deepfakes that reproduce an unpredictable challenge within the validity window, and the spoken challenge is a liveness cue rather than a complete presentation-attack detector.

## 3 The Proposed Scheme

The proposed scheme relates to multimodal biometric systems. Notably, it specifies a more secure and user-friendly biometric authentication system. This scheme provides a multimodal biometric authentication system that combines face and voice. In addition to biometrics, a dynamic CAPTCHA was also present. Each biometric feature proposed in the scheme and the CAPTCHA was extracted from the real-time recorded video. The three credentials used in the scheme are matched according to the AND logic rules. This ensures that successful authentication is achieved only when all the credentials are compared positively. ~~The present invention also provides an authentication system that involves the parallel acquisition of biometric features.~~The scheme therefore realises parallel acquisition of biometric features: a single video stream is the common source from which all factors are derived, so the acquisition cost is independent of the number of modalities.

### 3.1 System Model and Decision Rule

Let $V_r$ and $V_l$ denote the videos acquired during registration and login respectively, and let $C$ denote the CAPTCHA string issued by the server for the current session. Three decisions are derived from the single login stream:

- a face decision obtained by scoring the login recording's per-frame face embeddings against the enrolled face embedding at a threshold $\tau_f$;
- a voice decision obtained by scoring the login speaker embedding against the enrolled speaker embedding at a threshold $\tau_a$;
- a challenge decision obtained by transcribing the login audio and comparing the transcript with $C$.

Both biometric factors are scored by similarity rather than distance: each modality is reduced to an L2-normalized embedding, so the inner product of two embeddings is their cosine similarity and a factor is accepted when that similarity reaches its threshold. Let $e_r^f$ denote the enrolled face embedding and $\{e_{l,i}^f\}_{i=1}^n$ the per-frame embeddings of the login recording, and let $e_r^a$, $e_l^a$ denote the enrolled and login speaker embeddings. Writing $T(\cdot)$ for the speech-to-text transform and $\mathcal{N}(\cdot)$ for the CAPTCHA normalization map, the factor decisions are

$$b_f = \mathbb{I}\Big[\,\mathrm{median}_i \,\langle e_r^f,\, e_{l,i}^f\rangle \;\geq\; \tau_f\Big], \tag{1}$$

$$b_a = \mathbb{I}\Big[\langle e_r^a,\, e_l^a\rangle \;\geq\; \tau_a\Big], \tag{2}$$

$$b_c = \mathbb{I}\Big[\exists\, t \in T(A_l) : \mathcal{N}(t) = \mathcal{N}(C)\Big], \tag{3}$$

where $\mathbb{I}[\cdot]$ is the indicator function. The face score is the median of the per-frame similarities rather than the mean, so that a minority of degraded frames (motion blur, partial pose, transient occlusion) cannot move the verdict. The challenge

decision accepts if any transcription hypothesis matches after normalization, because the speech-to-text stage returns a ranked list of alternatives and the correct reading of a spoken digit string is frequently not the top-ranked one. Fusion is performed at the decision level under a conjunctive rule,

$$D = b_f \wedge b_a \wedge b_c, \tag{4}$$

and access is granted only when $D = 1$. A conjunctive rule is chosen deliberately: it lowers the false acceptance rate at the cost of a higher false rejection rate, which is the appropriate operating point for an authentication decision, and it guarantees that the compromise of any single modality cannot by itself produce a positive decision.

An important consequence concerns when the three decisions are computed. A conjunction may be evaluated lazily, aborting at the first negative factor, and this is what a cascaded formulation implies. The scheme deliberately does not do so: all three factors are evaluated concurrently and combined only once every verdict is available. Two properties motivate this. First, the response latency of a rejected attempt no longer depends on which factor failed, removing a timing side channel that would otherwise let an adversary probe the factors independently and reduce a conjunctive decision to three separate sub-problems. Second, the failing factor is never disclosed to the client—the rejection response is identical in every case, and the per-factor outcome is written only to the server log. Concurrent evaluation additionally overlaps the challenge branch with the biometric branch, which is the source of the latency reduction reported in Section IV.

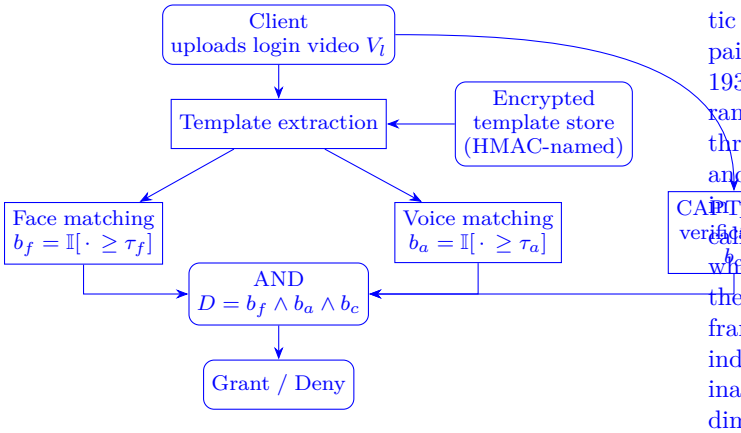



Fig. 4: Deployed concurrent authentication architecture. The uploaded login video feeds two independent branches evaluated in parallel: a biometric branch that reduces the recording to one login template and scores face and voice against the enrolled encrypted template, and a challenge branch that transcribes the audio and verifies it against the issued CAPTCHA. The enrolled reference is an AES-256-GCM encrypted, pseudonymously named template, never a stored recording. The three verdicts are combined by the conjunctive rule of equation (4); access is granted only when all three pass, and the response is identical whichever factor fails.

### 3.2 Feature Representations

The scheme is agnostic to the specific matchers, but the representations it instantiates determine whether the factors are genuinely discriminative, and two of the representations originally adopted were found not to be.

Face. The face factor was initially specified as a perceptual hash (pHash) of whole frames compared by Hamming distance. A perceptual hash summarises an entire frame—background, illumination and pose along with the subject—so it measures scene similarity rather than identity. On our own recordings the genuine pair 123 vs 123_l scored a Hamming distance of 26.0 against the specified acceptance threshold of 25, i.e. a genuine user was falsely rejected, while impostor pairs scored 30.0 and 32.0; the genuine and impostor populations are therefore not separated by a usable margin. The face factor accordingly uses face detection followed by a 512-dimensional deep embedding trained with an additive angular margin objective [36], compared by cosine similarity as in equation (1). On the same four pairs the embedding scores 0.7265 and 0.6194 for genuine pairs and 0.2247 and 0.1838 for impostor pairs against a threshold $\tau_f = 0.35$, separating both populations on this data. These are four pairs drawn from a handful of recordings, not an accuracy evaluation: they establish that the replaced statistic failed on cases where the embedding succeeds, and they are reported for that diagnostic purpose only. No false-acceptance or false-rejection rate is claimed from them. Twelve frames are sampled uniformly across each recording; the enrolled reference is the L2-normalized mean of the per-frame embeddings.

Voice. The voice factor was initially specified as a 13-coefficient MFCC matrix compared by mean pairwise Euclidean distance. Measured across the four enrolled templates then available, belonging to two distinct speakers, this statistic did not separate speakers at all: genuine same-speaker pairs scored 172.8–178.8 while impostor pairs scored 153.7–193.0, so the impostor range strictly contains the genuine range and the closest pair of all was an impostor pair. No threshold on this statistic separates speakers on this data, and the factor was observed accepting a different speaker in practice. The cause is structural rather than a matter of calibration—the distance is dominated by frame log-energy, whose zeroth coefficient is an order of magnitude larger than the remaining coefficients, and by the dispersion of the two frame clouds, i.e. by loudness and recording conditions. Text-independent speaker verification instead requires a discriminative learned embedding, so the voice factor uses a 192-dimensional ECAPA-TDNN speaker embedding [37] scored by cosine similarity as in equation (2), which is structurally the same decision the face factor makes. The operating threshold $\tau_a = 0.30$ is taken from a measured cosine distribution rather than assumed: over the labelled window pairs available, real cross-speaker pairs reached at most 0.256 while genuine same-speaker pairs floored at 0.345, and 0.30 lies in that gap. That distribution rests on two speakers, so it fixes a defensible operating point on the available data; it is not an equal-error-rate calibration and no error rate is claimed for it.

### 3.3 Security Mechanisms

Seven mechanisms carry the security argument of Section 1.5.

Template-only storage. No recording of any user is retained. The registration video is reduced to the two embeddings above and destroyed; only the embeddings are stored. This matters because an embedding is not a playable recording of the subject's face and voice, so a breach of the enrolment store does not yield reusable biometric media. The stored artefact is also two orders of magnitude smaller than the recording it replaces.

Encryption at rest with integrity. Templates are sealed under AES-256-GCM ~~using the dedicated template key $k_{\text{bio}}$ of the key-separation mechanism below~~under a key that belongs to a single enrolled identity, as described in the per-identity key mechanism below. The authenticated-encryption tag doubles as an integrity check: a template modified on disk fails authentication during decryption, and the scheme fails closed by rejecting the login rather than proceeding with unverified data. The login recording, which must persist briefly because two independent branches consume it, is encrypted under the same envelope ~~and the same key~~under the deployment-wide key $k_{\text{bio}}$, since it is transient and belongs to no enrolment, and deleted once the attempt resolves, whatever its outcome.

Key separation by security domain. The scheme keeps ~~three~~five cryptographic secrets, and no operation ever borrows one domain's secret for another's purpose:

- $k_{\text{sig}}$ signs session and enrolment tokens, and is used for nothing else. It authenticates statements; it encrypts no store.
- $k_{\text{bio}}$ seals ~~the biometric templates and~~ the transient login recording under AES-256-GCM, and keys the pseudonymous template names $\text{HMAC}(k_{\text{bio}}, \cdot)$ of the next mechanism. It no longer seals any template.
- $k_{\text{pii}}$ seals the account record's contact fields under AES-256-GCM and keys the email index $\text{HMAC}(k_{\text{pii}}, \cdot)$ used for duplicate detection.
- $k_{\text{mst}}$ wraps the per-identity template keys $k_u$ under AES-256-GCM before they are written to the key store, and never seals a template itself.
- $k_{\text{idx}}$ keys the pseudonymous key-store index $\text{HMAC}(k_{\text{idx}}, \cdot)$ under which a wrapped key is located, so that the key store holds no identifier.

The separation bounds what a single disclosure costs. An adversary holding $k_{\text{sig}}$ can forge tokens but cannot read a template or a contact field; one holding $k_{\text{bio}}$ can ~~decrypt templates and~~ re-derive template storage names and read a login recording still in flight, but cannot decrypt any stored template, which requires $k_{\text{mst}}$ and the separate key store, but learns nothing about addresses or telephone numbers; one holding $k_{\text{pii}}$ obtains the contact details but no biometric reference and no ability to mint a token. Deriving all ~~three~~five from one secret—or, in the common shortcut, deriving the storage keys from the token-signing secret—would make each of those compromises the others as well, so the separation is enforced rather than merely recommended: a deployment configured for production refuses to start unless all ~~three~~five secrets are supplied explicitly and each is at least 32 characters, with ~~$k_{\text{bio}}$ and $k_{\text{pii}}$ additionally required to differ from one another and from $k_{\text{sig}}$~~every pair additionally required to differ, and with the key store required to be a distinct store from the account database. The signing key is subject to the same requirement in its own right, and for a reason that does not involve encryption at all: its development fallback is a constant that appears in the published source, so a deployment running on it would let anyone forge a session token—bypassing authentication outright—or an enrolment token, which is precisely the capability the enrolment-binding mechanism below exists to withhold. A production configuration that supplies that placeholder value, or a short one, is rejected exactly as a missing storage key is. The check runs before the service accepts any request and before any maintenance task can touch the stores, so a misconfigured deployment fails visibly at startup instead of serving traffic while protecting its data with a secret intended for a different purpose. A development checkout with no keys configured falls back to derived values so that a fresh clone runs; that fallback is a convenience for development only, is announced on startup, and is exactly what the production check refuses. What key separation does not do should be equally clear: it bounds the blast radius of a key disclosure, and it neither prevents a database compromise nor, on its own, prevents account takeover—the mechanisms below address that.

Per-identity template keys. Domain separation bounds what one disclosure costs across stores, but a single key per domain leaves the biometric store internally undivided: one key $k_{\text{bio}}$ seals every template, so disclosing it discloses the enrolled population at once. The scheme therefore narrows the unit of compromise from the store to the record. At enrolment the server draws a fresh 256-bit key $k_u \leftarrow \{0,1\}^{256}$ from a cryptographically secure generator, independently for each identity, and seals that identity's template under $k_u$ alone. Two properties are deliberate. First, $k_u$ is random, not derived from the biometric evidence: a template is not reproducible byte for byte across acquisitions, so any construction that hashed an embedding into a key would fail to reproduce it at verification, and would in addition make the key as guessable as the trait. Second, $k_u$ is independent of the enrolment token of the binding mechanism below; that token is an authorisation credential with a ten-minute lifetime and is never retained as key material.

The plaintext $k_u$ is never written to any store. It is wrapped as $\text{AEAD}_{k_{\text{mst}}}(k_u)$ under the master key, with the record's index and key version supplied as associated data so that a wrapped key transplanted onto another record fails its authentication tag, and only the wrapped form is persisted. The wrapped keys live in a store separate from the account database, indexed by $\text{HMAC}(k_{\text{idx}}, \text{id})$ rather than by identifier, and carrying a version field so that re-keying an individual record remains expressible. The account records themselves are untouched by this mechanism: no key material is added to them, and the two stores remain independently administrable.

Verification is correspondingly narrow. The verifier derives the index from the claimed identifier, retrieves the wrapped key, unwraps it under $k_{\text{mst}}$ and decrypts that identity's template and no other; the plaintext key exists only for the duration of the operation and is erased afterwards. Every step fails closed—an absent record, a wrapped key that fails its tag, a template that fails its own—and each failure yields the same generic rejection. There is no fallback to a deployment-wide key: a template whose per-identity key is unavailable is unreadable by construction rather than readable under a key

shared with every other enrolment. The resulting property is containment: an adversary who obtains one identity's key obtains one template, an adversary who obtains the template directory alone obtains ciphertext for which no key is present, and an adversary who obtains the key store alone obtains wrapped keys without the templates they open. Only $k_{\text{mst}}$ together with the key store and the template store reconstitutes the plaintext population, which is the concentration the mechanism is intended to create and which correspondingly concentrates the consequence of its disclosure.

Pseudonymous storage (unlinkability). Confidentiality and integrity protect a template's contents, but they say nothing about what its name discloses. If a stored template is named after the account it belongs to, then a compromise of the storage directory alone—without the database and without the encryption key—reveals the entire enrolled membership by name and yields one labelled biometric template per person, each reusable for cross-system correlation. This is the unlinkability concern of ISO/IEC 24745. Each template is therefore stored under a name that is a keyed hash of the identifier, $\text{HMAC}(k_{\text{bio}}, \text{id})$ under the same template key $k_{\text{bio}}$ that protects the templates, rather than under the identifier itself. A keyed hash rather than a plain one is deliberate: identifiers are low-entropy and would fall to a dictionary against an unkeyed digest, whereas an adversary who lacks $k_{\text{bio}}$ cannot map a stored name back to an identity, and one who possesses $k_{\text{bio}}$ can already decrypt the templates, so no additional linkage is conceded. Binding the name to the same key as the contents is deliberate in the other direction too: the naming key and the sealing key share a lifecycle, so a change of $k_{\text{bio}}$ invalidates the names and the decryptability of the templates together rather than leaving one valid and the other stale. That coupling is a consistency property, not a rotation capability—see the operational limitation stated in Section 4.5. The mapping is deterministic, so verification re-derives the name at login without any stored lookup table, and no plaintext identifier is written to the template store.

Scope of the unlinkability property. This property applies to the biometric template store and should be read accordingly, including the Unlinkable rating in Table 7. It does not extend to the account database, which is a separate store. Authentication necessarily requires an account record, and that record holds the account information supplied at registration—a unique username and email, and optionally profile fields such as name, mobile number and address. Of these, only the username is stored in the clear, and deliberately so: it is the lookup key queried on every login, it is submitted by the client on every request, and sealing it would impose a blind index on the hot authentication path while concealing nothing that the client does not already transmit. Every other field—email address, first and last name, mobile number, postal address and the optional avatar—is sealed under AES-256-GCM with the account key $k_{\text{pii}}$ before it is written, and opened when the profile is served. The property this provides should be stated exactly: it is confidentiality of the account record at rest, so that a compromise of the database itself—a dump, a stolen backup, an exposed instance—yields ciphertext for every contact field. It is not an access-control property of the running service, because the prototype's profile endpoint is not authenticated and will open a record for any caller that names the identifier; adding that control is a deployment measure independent of the encryption described here. The key is the account domain's own, distinct from the template key $k_{\text{bio}}$ and from the signing key $k_{\text{sig}}$, so a disclosure confined to one domain does not extend to the others. The email address additionally carries a keyed-hash index, $\text{HMAC}(k_{\text{pii}}, \mathcal{N}_e(\text{address}))$ over the case- and whitespace-normalized address, which preserves the equality test that duplicate-registration checking needs without the server ever comparing—or being able to read—a stored address. Ciphertext cannot serve that purpose itself, because the random initialisation vector makes two records holding the same address differ byte for byte; the index is keyed rather than a plain digest because addresses are guessable and an unkeyed digest would fall to a dictionary. The index is never returned to the client, since it is a stable handle for the address it stands in for. The two stores are decoupled: the account database contains no template and no template file name, while the template store contains no plaintext identifier, so the templates are pseudonymously identified and stored separately from the account information. A compromise limited to the template directory therefore discloses neither identities nor a mapping from a stored template to one, which is the property claimed; a compromise of the account database discloses the enrolled usernames, but neither the contact details, which are ciphertext under a separate key, nor any biometric template. Unlinkability is thus a property of the biometric template store, not of the account database: the account database is confidentiality-protected but not unlinkable, since its usernames remain readable, and making them unlinkable too would require a blind index on the login lookup path and would not conceal the identifier the client transmits on every attempt in any case. What the account encryption does buy is that the personal data attached to an identity—address, telephone number, email—no longer follows from a database dump, so the residual disclosure is the membership list rather than the contact list. Minimising the fields collected remains an orthogonal measure, and neither affects the biometric protections described above.

Enrolment binding. The identity being enrolled is established by a short-lived server-signed enrolment token issued once, at account creation, and never by client-supplied data such as a filename. The deployed validity period is ten minutes: long enough to re-record and retry a failed upload, short enough that a leaked token is not a standing licence to re-enrol the account. This closes an account-takeover path: if the enrolled identity is read from the uploaded filename, any unauthenticated client can replace another user's stored template with its own biometrics and then authenticate as that user. Because account creation rejects any identifier that is already enrolled, a token can never be minted against an existing enrolment, and the enrolment endpoint independently refuses an upload for an identifier that already holds a template, so a stored template is never replaced—not even by the holder of a valid token. A session token is explicitly not accepted for enrolment, so a stolen session cannot re-key an account. The qualifier enrolled is deliberate. Registration spans two requests, so it can stop between them and leave an account that holds no template. Such an account is inert—it cannot authenticate, because there is nothing to match against—but it would otherwise hold its identifier perma-

nently, since its enrolment token expires and no second one can be issued. A failed extraction therefore rolls the account back, an identifier held by an account with no template is released to a later registration, and an enrolment is refused if the account it names no longer exists. Releasing an unenrolled identifier surrenders no biometric reference, because none was ever bound to it; releasing an enrolled one would be the takeover this mechanism exists to prevent, and is what the template check above forbids. One consequence of releasing an identifier should be stated precisely, because it follows from what the deployed token actually carries. The token binds the identifier and the purpose, but no account instance, and the enrolment endpoint accordingly locates the account by identifier alone. An identifier released while a previously issued token for it is still inside its ten-minute window can therefore be enrolled, by the holder of that earlier token, onto the account that subsequently claimed the same identifier. Binding the token to the account instance—by carrying an account reference in the token and requiring it to match—would remove this, and is not implemented in the prototype described here.

Challenge handling. The challenge is generated server-side and only its rendered image is transmitted; the expected string never reaches the client, since a client that knows the expected text can satisfy the challenge without a live utterance. Each challenge is bound to one identifier, is consumed on the first verification attempt whether or not that attempt succeeds, and expires after a fixed window of five minutes. A login recording is accepted for upload only while an issued, unexpired challenge exists for that identifier, so a recording cannot be submitted outside a live login attempt. The challenge alphabet is restricted to five decimal digits. This is a deliberate consequence of the recognition stage rather than a security choice: transcription of arbitrary letter strings proved unreliable, whereas digit sequences transcribe dependably, and the comparison of equation (3) normalizes spelled-out number words to numerals before matching so that a correct utterance is not rejected for orthographic reasons. The reduced alphabet lowers the entropy of a single challenge, which is acceptable only because the challenge is not a standalone credential: it is conjoined with two biometric factors under equation (4), and guessing it confers nothing without also passing them.

Input validation. Every identifier that reaches a filesystem path or a subprocess argument is validated against a restrictive character class at account creation, at enrolment and at login, and the uploaded filename is pattern-checked rather than trusted. Without this, an identifier containing path separators would escape the intended storage directory, and the enrolled identity is in any case taken from the signed token rather than the filename.

The proposed authentication scheme's registration phase considers Email address and unique username. After this, the user records the real-time video while speaking the dynamic CAPTCHA. This recording is reduced to the biometric templates defined in Section 3.2, which are encrypted and stored; the recording itself is discarded and is never written to persistent storage. The proposed authentication system uses biometric features of face and voice. The user is required to capture a real-time video. However, while recording the video, the user must speak the dynamic CAPTCHA displayed on the screen. From this real-time recorded video, face, voice and CAPTCHA are extracted. The corresponding reference is not a stored recording but the encrypted template enrolled for that identifier, which was derived once at registration and retained in place of the video. Matching therefore compares the login embeddings against the enrolled embeddings, never against a second recording. Also, the voice/audio is converted to text and matched with the dynamic CAPTCHA text displayed on the screen. All these matching results are then applied AND logic, which ensures positive authentication only if all the results are positive. These results are combined to decide whether the authentication is successful and give the final decision. Dynamic CAPTCHA reduces video reuse/replay attacks and adds to the liveliness detection of a specific user.

Initially, we start with entering a unique username that helps in user identification and then a real-time video capturing field and dynamic CAPTCHA is displayed. The individual trying to authenticate themself records real-time video while speaking dynamic CAPTCHA, displayed on the screen. From this recorded video, frames are extracted. Also, audio is extracted from this recorded video. The per-frame embeddings computed from these frames are scored against the enrolled face embedding stored for that identifier. Similarly, the speaker embedding computed from the login audio is scored against the enrolled speaker embedding to decide whether the person speaking is the enrolled user. No registration audio exists on the server to be re-extracted. Also, the extracted audio is converted to text matched with the CAPTCHA displayed for CAPTCHA validation checking. After matching frames and audio is complete, the matching score is checked to see if it is above a certain threshold and matching is successful. Then, all these results are subjected to AND logic, which gives positive results only if all validations and matching are positive. The user is granted access to resources if the result is positive. Otherwise, access is not granted.

There are three phases involved in this authentication scheme -

- Registration Phase
- Login Phase
- Authentication phase

### 3.4 Registration Phase

Following steps are involved in the registration phase:

1) Initially, the user enters their personal information - Email ID username. The username and Email ID needs to be unique for each individual.
2) In the next step, a dynamic CAPTCHA is displayed on the screen, and a video recording interface is presented. The user has to record their video while speaking the CAPTCHA showed. The challenge shown at registration is generated on the client and serves only to elicit natural speech for the voice template; it is not verified, and no security property is claimed for it. The challenge is a verified factor at login only, where it is server-generated, withheld from the client, and checked against the transcript by equation (3).
3) On clicking the start recording button, the video recording will start. On clicking stop recording, the recorded video is available for preview.

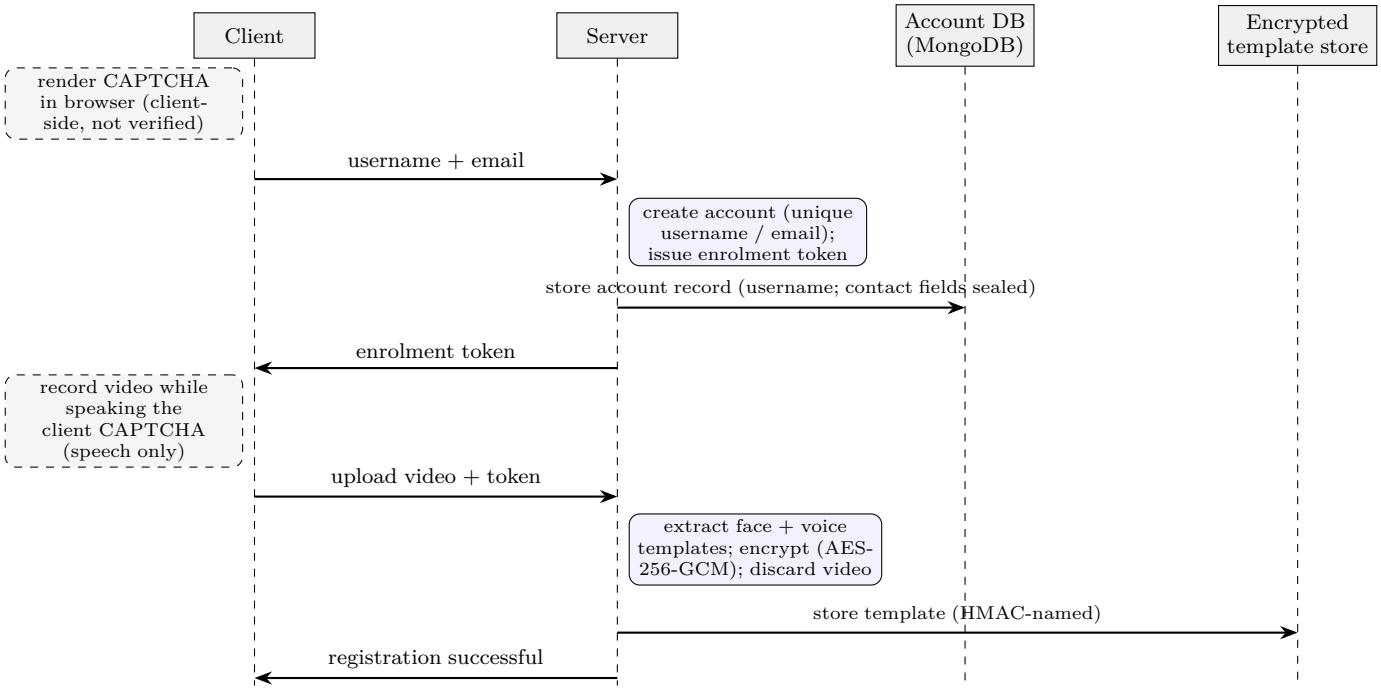



Fig. 5: Registration phase (deployed). The account record is written to MongoDB with only the username readable—the email, name, mobile number, address and avatar are encrypted under the account key $k_{\text{pii}}$, and the email additionally carries an HMAC($k_{\text{pii}}, \cdot$) index so duplicate registrations are still detected— while the uploaded recording is reduced on the server to face and voice templates encrypted under the separate biometric key $k_{\text{bio}}$ and stored under an HMAC($k_{\text{bio}}, \cdot$) name in a separate store; the video is never persisted. The two stores are decoupled: the account DB holds no template, the template store holds no plaintext identifier. The CAPTCHA shown at registration is generated client-side and is not verified—it only elicits natural speech for the voice template; the challenge is a verified factor at login (Fig. 6) only. Enrolment is authorized by a one-time server-signed token, not by the uploaded filename.

4) On clicking save, the recording is uploaded and immediately reduced on the server to the face and voice templates. The templates are encrypted under AES-256-GCM with the biometric key $k_{\text{bio}}$ and stored as the enrolment reference, under a name that is a keyed hash of the identifier under that same key; the uploaded recording is held only in memory and in a temporary file that is deleted once extraction completes. If no usable face can be extracted, no template is stored and the enrolment is rejected, so an account can never reach a state where it has an unusable reference. Because the account record is created by the preceding request, an enrolment rejected at the extraction stage also deletes it; a failure that occurs after extraction, while the template is being sealed and written, returns an error and leaves the account in place with no template. Either way an identifier left held by an unenrolled account is released to a later registration, so the second case is recovered by the first mechanism rather than by a second rollback; an enrolled account, by contrast, is never displaced
5) On clicking the register button, the user is registered successfully if the submitted credentials pass all the checks implied. Users can further update their information like address, full name, etc.

The registration-page screenshot previously shown here has been withdrawn. It depicted a save button that the current client no longer has, and it showed an identifiable participant. The registration workflow is specified in the enumerated steps above and in Fig. 5. ~~Figure: Registration page after entering credentials.~~

### 3.5 Login Phase

The following steps are involved in the login phase:

1) The user enters the username submitted at registration. If the username does not match that submitted at registration, we cannot proceed further.
2) A dynamic CAPTCHA is also displayed on the screen. This is server-side CAPTCHA, which is dynamic.
3) The User trying to log in needs to record a video while speaking the CAPTCHA displayed.
4) On clicking the start recording button, the video recording will start. On clicking stop recording, the recorded video is available for preview.
5) On clicking save, the login recording is encrypted under the biometric key $k_{\text{bio}}$ and written to a transient location, because two independent verification branches consume it. It is deleted as soon as the attempt resolves, so no login recording is retained either.

The login-page screenshot previously shown here has been withdrawn. It displayed a four-character alphanumeric challenge, which contradicts the five-digit challenge specified in Section 3.3, and a save button absent from the current client; it also showed an identifiable participant. The login workflow is specified in the enumerated steps above and in Fig. 6. ~~Figure: Login Steps.~~

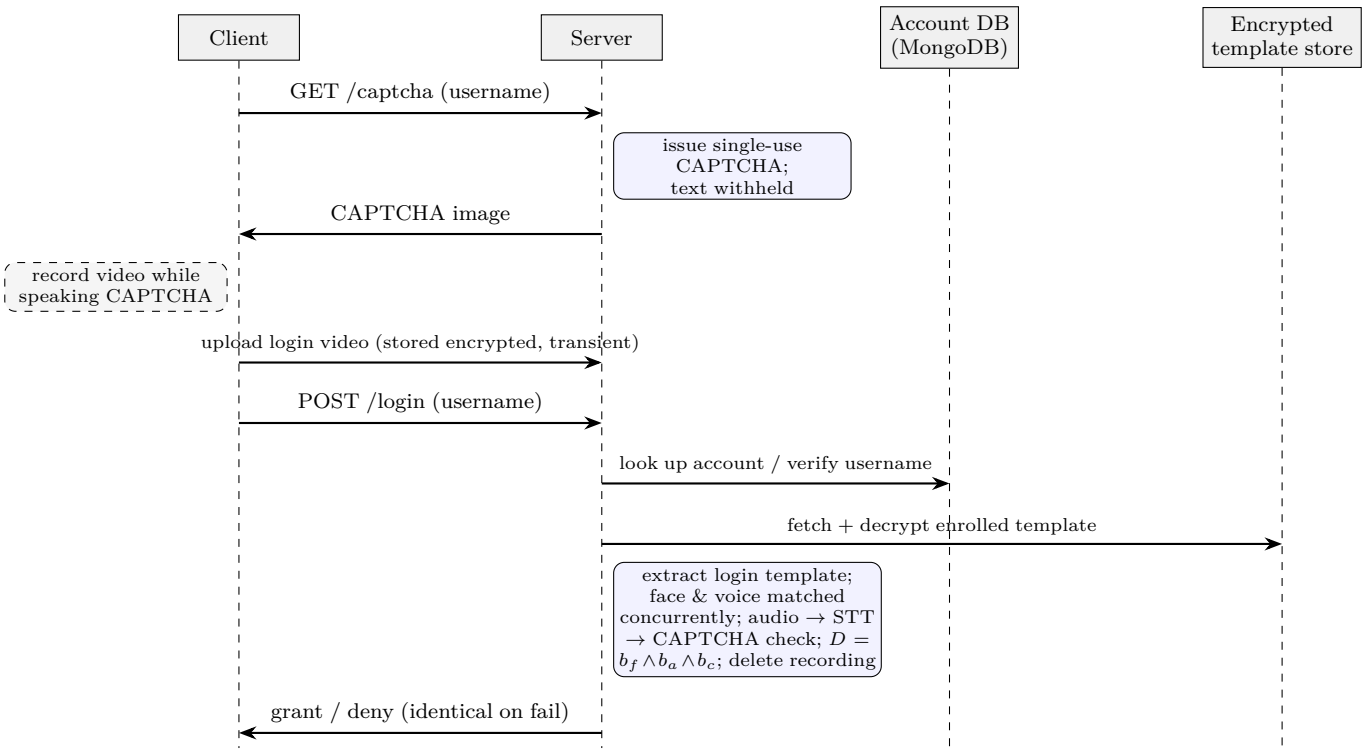



Fig. 6: Login and authentication phase (deployed). The account is looked up in MongoDB by username, while the enrolled reference is a decrypted template fetched from the separate encrypted template store—never a stored recording. CAPTCHA issuance and video upload are distinct requests preceding the login request; the CAPTCHA text is issued server-side and withheld from the client. The three factors are evaluated concurrently and combined by the conjunctive rule of equation (4); the response is identical whichever factor fails, and the login recording is deleted once the attempt resolves.

### 3.6 Authentication Phase

The following steps are involved in the authentication phase: The steps below supersede an earlier formulation in which each factor gated the next and the enrolled reference was read from a stored recording. Neither is the case: the enrolled reference is a template, no recording of any user exists on the server to be read, and the three factors are evaluated concurrently.

1) The submitted identifier is checked against the enrolled accounts.
2) The challenge issued to this identifier is retrieved and consumed, so that it cannot be reused by a subsequent attempt regardless of the outcome of this one.
3) The enrolled template and the freshly uploaded login recording are decrypted into a private working directory. Failure to decrypt or authenticate either artefact rejects the attempt immediately.
4) The login recording is reduced once to a login template, yielding its per-frame face embeddings and its speaker embedding.
5) The face and voice factors are scored against the enrolled template concurrently, by equations (1) and (2).
6) Concurrently with the above, the challenge branch demultiplexes the login audio, transcribes it, and evaluates equation (3). This branch depends only on the login audio, so it does not wait on the face verdict.
7) The three verdicts are combined by the conjunctive rule of equation (4). On success a signed session token is issued; on failure the response is identical irrespective of which factor failed.
8) The working directory and the login recording are destroyed, whatever the outcome.

## 4 Implementation and Analysis

### 4.1 Experimental Setup

~~To perform authentication, a website was developed which shows the authentication steps involved for checking the real-time working of the proposed scheme.~~A proof-of-concept web application was implemented to validate the feasibility of the proposed scheme under real-time acquisition. The prototype follows a client–server separation of concerns: the client is responsible only for acquisition and for presenting the server-issued challenge, while enrolment references, challenge generation, feature extraction, matching and the fusion decision of equation (4) are executed on the server. Keeping the decision logic server-side is a security requirement rather than an implementation detail, since a client-side decision could be bypassed by a modified client.

#### 4.1.1 Hardware Requirements

The Laptop used for experimenting was an Intel(R) Core(TM) i5-4210U CPU @ 1.70GHz 2.40 GHz with 8.00 GB installed RAM. The system was a 64-bit operating system, x64-based processor. The system was running Windows Operating system with edition Windows 10 Education, version 22H2, and OS build 19045.2965. The website was hosted on

localhost in Chrome browser Version 114.0.5735.110 (Official Build) (64-bit). The functional behaviour of the scheme was verified on this machine. The timing measurements reported in Section 4.2 were collected on a separate host—an Intel Core i9-12900 (24 threads) with 62 GB of RAM, running the server runtime and a local database instance—because the biometric pipeline is model-load bound and timings taken on the first machine would not be representative of the deployed configuration. The two machines are therefore not interchangeable, and the latency figures should be read against the second one.

#### 4.1.2 ~~Software Requirements~~ Prototype Architecture

~~The experiment requires the editor Visual Studio Code Version 1.79.0 (user setup). The front end of the proposed scheme was built in React JS, and the back end was built in Node JS. This experiment requires Node.js 16.17.1. The database used is MongoDB, and we use MongoDB Atlas. The experiment further requires some packages like FFMPEG [38], speechRecognition [39] library, librosa [40] for audio-related tasks and svgCaptcha [41] for server-side CAPTCHA generation.~~The prototype is organised as a three-tier architecture. The presentation tier is a single-page browser client that performs media capture and renders the challenge; the application tier is an event-driven server that generates the per-session CAPTCHA, orchestrates the extraction and matching pipeline and evaluates the fusion rule; and the persistence tier stores the enrolment reference associated with each unique identifier. The processing pipeline itself is realised through four functional components, each of which is independent of the specific library that implements it: a demultiplexing component that separates the video and audio streams of the acquired recording [38], a spectral analysis component that derives the audio feature representation [40], a speech-to-text component that produces the transcript used for challenge validation [39], and a challenge generation component that issues an unpredictable server-side CAPTCHA per session [41]. This decomposition is deliberate: because the components interact only through the representations defined in Section III, an individual matcher can be replaced by a stronger one without altering the system model or the decision rule. The prototype was realised as a JavaScript web application with a document-oriented store, with the media processing components invoked from the application tier. Key material is supplied to the application tier as ~~three~~five independent configuration secrets, one per domain of Section 3.3: a token-signing secret, a ~~biometric-template key~~recording-and-naming key, an account-PII key, a key-wrapping master key and a key-store index key; the per-identity template keys are generated by the server and are not configured. A deployment marked as production validates all ~~three~~five before the service accepts any request—each must be present and at least 32 characters, the signing secret must not be the placeholder value carried in the source for development use, and ~~the two storage keys must differ from each other and from the signing secret~~every pair of secrets must differ, with the key store additionally required to address a database distinct from the account database—and terminates with a diagnostic naming every violated condition if any fails, so a deployment cannot silently protect its stores with a secret intended for another purpose. The same validation guards the offline maintenance tasks, so a migration cannot be run against a production store under the wrong keys. In a development checkout the secrets may be left unset, in which case the signing secret takes a placeholder value and the storage keys are derived from it, both announced at startup; this is a convenience for local work only and is precisely the configuration the production check rejects. Key rotation is not automated in the prototype and is discussed as an operational limitation in Section 4.5. For reproducibility the concrete stack is recorded here: a React single-page client, an Express server on Node.js 22, MongoDB for account records, and Python 3.12 for the biometric pipeline, with the face and speaker models executed on CPU through ONNX Runtime and PyTorch respectively. The pinned dependency set is distributed with the implementation.

### 4.2 Processing and Communication Overhead

A multimodal scheme is only deployable if the additional verification it performs does not dominate the interaction, so the per-stage and end-to-end costs were measured rather than estimated. Each stage was timed over $N = 5$ runs of a genuine login, on the machine described in Section 4.1.1. All five runs returned a successful authentication with all three factors positive, so the timings are for the full success path and not for an early rejection.

TABLE 3: Measured per-stage processing time (ms, $N = 5$)

| Stage | Mean | Min | Max |
|---|---|---|---|
| Login template extraction | 12424 | 11888 | 12779 |
| Face matching | 98 | 73 | 116 |
| Voice matching | 104 | 83 | 138 |
| Audio demultiplexing | 154 | 146 | 162 |
| Speech-to-text | 2367 | 2085 | 2666 |

Template extraction dominates every other stage by two orders of magnitude. The reason is architectural rather than algorithmic: it is the one stage that loads both model stacks—the face embedding network and the speaker embedding network—into a freshly created interpreter and then runs both. Matching itself is negligible on both factors, because each is a single inner product between stored vectors. The speaker-embedding migration described in Section 3.2 in fact moved cost out of the per-login matcher, reducing voice matching from 682 ms to 104 ms, and into the one-time extraction stage.

TABLE 4: End-to-end authentication latency (ms, $N = 5$)

| Pipeline | Mean | Min | Max |
|---|---|---|---|
| Cascaded (original formulation) | 15320 | 14336 | 15698 |
| Concurrent (deployed) | 13293 | 12571 | 13700 |

Concurrent evaluation saves approximately 2027 ms per authentication, a speedup of 1.15×. The modest ratio is itself informative: the speedup is bounded by template extraction, because the challenge branch it overlaps with (roughly 2521 ms of demultiplexing and transcription) is far shorter than the 12424 ms extraction it hides behind. Further latency reduction must therefore come from amortising model loading—a resident model service rather than a fresh process per authentication—and not from additional concurrency. This is a deployment change rather than an algorithmic one and was not attempted here.

On communication cost, the client uploads one recording per attempt, which is unchanged from the original design. What changed is what the server retains: a stored template of approximately 147 KB in place of an 11.18 MB recording, roughly a 76-fold reduction, with a fixed 34-byte overhead for the encryption envelope. Because the authenticated cipher mode used is a stream mode, ciphertext length equals plaintext length and encryption adds no further storage cost. Upload times over a range of uplink bandwidths can be derived from the recording size but were not measured over a live link, and are therefore not reported as experimental results.

### 4.3 Evaluation Datasets

The evaluation draws on three sources, each answering a different question, and no result from one is presented as evidence for another. Table 5 summarises them; ~~every experimental quantity in it is marked n/a until the corresponding run has been performed.~~a quantity is marked n/a where the corresponding run has not yet been performed. The CREMA-D results are reported in Section 4.4.

Public audio-visual corpus (recognition accuracy). Face and voice recognition accuracy—false acceptance, false rejection, equal error rate and the detection-error trade-off—is measured on CREMA-D [42], a publicly released corpus of short audio-visual clips of actors speaking fixed sentences, distributed under the Open Database License with the actors' consent to open release. The deployed speaker model is trained on VoxCeleb, so CREMA-D lies outside its training data and the voice error rate is not measured on data the model has seen. ~~The corpus is mapped onto the harness by treating distinct sentence-emotion takes of one actor as separate sessions; genuine pairs are formed only between different takes of the same actor and impostor pairs between different actors, and no clip is compared with itself.~~Two protocols are defined on it. The MAIN protocol uses the neutral-emotion clip of each of the twelve dataset sentences per actor; a genuine pair is two clips of the same actor speaking different sentences. The SECONDARY protocol uses one sentence spoken in three acted emotions (anger, disgust, fear); a genuine pair is the same actor and sentence in two different emotions, so it isolates within-speaker variation due to emotion. In both, impostor pairs are formed between clips of different actors and no clip is compared with itself. All takes of an actor come from one studio sitting on one device, so this source supports genuine/impostor separation but not a cross-day or cross-device claim, and none is drawn from it. Because its speakers read dataset sentences rather than the issued challenge, it is not used for the challenge factor.

Own consented recordings (cross-session and attack evaluation). Within-person variation across time and devices, the challenge factor, and resistance to the attacks of Section 3.1 are measured on recordings collected from volunteers through the deployed application in a dedicated evaluation mode. The mode is disabled by default and is enabled only by an explicit server-side configuration flag; while it is active, the registration and login pages display a research-recording notice and a consent checkbox, and a recording is retained only when that checkbox accompanied the specific upload. Raw media were retained only in this consented evaluation mode, in a directory separate from the production template store; with the mode disabled the deployed behaviour is unchanged and every recording is reduced to an encrypted template and deleted. Each retained clip is named by the keyed-hash pseudonym of the account, the session number and the challenge code the participant was shown, so the spoken content of every clip is known and the challenge factor and replay, splicing and photo attacks can be scored against it. The collection protocol is two sessions per volunteer, on different days where possible and otherwise at least two hours apart, at least two genuine logins per session, and at least two capture devices (a laptop webcam and a mobile phone) where available.

Deployment template analysis (impostor behaviour of the deployed store). The encrypted templates held by the deployed system are analysed as they stand. Each template is decrypted in memory only, under its own per-identity key from the key store, and no plaintext embedding is written to disk. Every pair of enrolled templates is scored with the deployed face and voice matchers, which yields the impostor score distribution of the live store and the number of pairs that would exceed $\tau_f = 0.35$ and $\tau_a = 0.30$. Accounts whose templates indicate the same person are identified and, once confirmed, excluded from the impostor set rather than counted as impostors. This source cannot supply genuine cross-session scores: the enrolment recordings were destroyed by design, and the login log records each factor's decision but not its score.

### 4.4 Recognition Accuracy on CREMA-D

Table 6 reports the face and voice factors and their conjunctive fusion on the two CREMA-D protocols of Section 4.3. Every recording is processed by the deployed extraction path and scored by the deployed matchers, and the error rates are taken at the deployed thresholds $\tau_f = 0.35$ and $\tau_a = 0.30$, which were fixed before this evaluation and are not retuned on it. The equal error rate and the threshold at which it occurs are given as reference operating-point statistics only; neither is the operating point of the scheme.

Confidence intervals. Pairwise scores that share an actor are correlated, so resampling individual pairs would understate the uncertainty. The 95% intervals are therefore obtained by an actor-level bootstrap with 5,000 replicates: each replicate draws 91 actors with replacement, keeps every genuine pair of each drawn actor, forms impostor pairs between draws of different actors, and recomputes the pooled rates; the interval is the 2.5th to 97.5th percentile. Where no error was observed the bootstrap cannot bound the rate, and the table instead reports the observed count together with the rule-of-three upper bound $3/N$; that bound assumes independent trials, which correlated pairs are not, and is therefore approximate.

Emotion, not the pipeline, drives the voice false rejections. The voice factor rejects 22.71% of genuine pairs when the two clips differ in acted emotion (SECONDARY) but 6.13% when both are neutral and differ only in sentence (MAIN); the genuine median rises from 0.417 to 0.468 while the impostor median is essentially unchanged (0.082 and 0.079). Because every voice rejection is also a rejection of the fused decision, the fused false rejection rate equals the voice rate in both

TABLE 5: Evaluation data sources. n/a: not yet run. ~~*CREMA-D sessions are three emotion takes of one sentence from a single studio sitting on one device, not separate days or devices.~~Both CREMA-D protocols come from a single studio sitting on one device; their clips are not separate days or devices. MAIN: neutral emotion, twelve sentences, genuine = same actor, different sentence; 86 actors contribute 12 clips, 4 contribute 11 (one sentence absent from the release) and one contributes 10, 1,086 clips in all (a further clip, 1076_MTI_NEU, is truncated to 0.07 s in the release and excluded). SECONDARY: one sentence in three acted emotions, genuine = same actor and sentence, different emotion. EER is a reference statistic only; results at the deployed thresholds are in Table 6.

| Source | Used for | Subjects | ~~Sessions~~ Clips/subject | Genuine pairs | Impostor pairs | EER (face / voice) |
|---|---|---|---|---|---|---|
| ~~CREMA-D (public)~~ | ~~Recognition accuracy (FAR, FRR, EER, DET)~~ | ~~91~~ | ~~3*~~ | ~~273~~ | ~~36,855~~ | ~~0.00% / 8.73%~~ |
| CREMA-D, MAIN (public) | Recognition accuracy across sentences (FAR, FRR, EER) | 91 | 10–12 | 5,941 | 583,214 | 0 / 3.15% |
| CREMA-D, SECONDARY (public) | Recognition accuracy across acted emotions (FAR, FRR, EER) | 91 | 3 | 273 | 36,855 | 0 / 8.73% |
| Own consented recordings | Cross-session and cross-device accuracy; challenge factor; attacks | n/a | n/a | n/a | n/a | n/a / n/a |
| Deployment templates | Impostor score distribution of the deployed store | n/a | 1 | – | n/a | – |

TABLE 6: Recognition accuracy on CREMA-D at the deployed thresholds $\tau_f = 0.35$, $\tau_a = 0.30$. Brackets: 95% actor-level bootstrap interval (5,000 replicates). †No error observed; approximate rule-of-three 95% upper bound $3/N$, which assumes independent pairs. EER and EER threshold are reference statistics, not the operating point; a face EER of 0 means the genuine and impostor score ranges are disjoint, so the EER threshold is any value in the stated interval. MAIN: 5,941 genuine / 583,214 impostor pairs; SECONDARY: 273 / 36,855. ‡Rate at which a genuine user is rejected on two attempts with different clips against the same enrolment; one trial per actor, reference clip and unordered pair of two further clips (59,100 trials).

| Protocol | Factor | FAR at deployed $\tau$ | FRR at deployed $\tau$ | EER (reference) | EER threshold | AUC |
|---|---|---|---|---|---|---|
| MAIN | Face | 0 / 583,214 obs.; $\leq$0.0005%† | 0 / 5,941 obs.; $\leq$0.0505%† | 0 (disjoint) | any in (0.339, 0.771) | 1.0000 |
| | Voice | 10,069 / 583,214 = 1.73% [1.40%, 2.14%] | 364 / 5,941 = 6.13% [4.52%, 7.88%] | 3.15% [2.60%, 3.71%] | 0.267 [0.256, 0.277] | 0.9949 |
| | Fused AND | 0 / 583,214 obs.; $\leq$0.0005%† | 364 / 5,941 = 6.13% [4.52%, 7.88%] | – | – | – |
| | Fused AND‡ | – | one retry: 777 / 59,100 = 1.31% [0.77%, 1.97%] | – | – | – |
| SECONDARY | Face | 3 / 36,855 = 0.01% [0.00%, 0.05%] | 0 / 273 obs.; $\leq$1.10%† | 0 (disjoint) | any in (0.395, 0.697) | 1.0000 |
| | Voice | 964 / 36,855 = 2.62% [2.08%, 3.25%] | 62 / 273 = 22.71% [16.85%, 28.94%] | 8.73% [6.54%, 10.90%] | 0.222 [0.205, 0.243] | 0.9634 |
| | Fused AND | 0 / 36,855 obs.; $\leq$0.0081%† | 62 / 273 = 22.71% [16.85%, 28.94%] | – | – | – |

protocols. To exclude a processing artefact as the cause, the SECONDARY voice embeddings were re-extracted from the corpus's separately distributed 16 kHz PCM audio instead of the audio track of the video files. The two sources carry the same speech (median aligned waveform correlation 0.993) and differ only in level and a short onset delay, and the PCM path did not raise genuine scores (median 0.402 against 0.417; FRR 20.15% against 22.71%, obtained at a higher FAR of 3.70% against 2.62%). The high SECONDARY rejection rate is therefore attributed to within-speaker variation under acted emotion on short utterances, and the deployed audio path was left unchanged.

A single retry recovers most, but not all, false rejections. A genuine user rejected at login can try again with a new recording. On MAIN, the rate at which two attempts with different clips are both rejected against the same enrolment is 1.31% [0.77%, 1.97%] (777 of 59,100 trials), against 6.13% for one attempt; all of these rejections come from the voice factor, as no face genuine pair is rejected. Were the two attempts independent the retry rate would be $0.0613^2 \approx 0.38\%$; the measured rate is about 3.5 times that, because rejections cluster by speaker and by enrolment clip: 43 of the 91 actors have at least one failed retry, and the worst single actor fails both attempts in 19.4% of trials. A retry also gives an impostor a second chance; no single fused impostor attempt was accepted on MAIN, so none of their pairings is accepted either, but for the voice factor alone the per-attempt false acceptance rate of 1.73% would roughly double. The figure describes exactly one retry, not any attempt-limiting policy, and holds for the single-sitting conditions of the corpus.

The face margin is thin at the impostor end. No face impostor pair was accepted in MAIN, but the highest impostor score, 0.339, lies only 0.011 below $\tau_f = 0.35$, and in SECONDARY three of 36,855 impostor pairs reached or exceeded it (maximum 0.395). The face genuine scores sit far above the threshold (MAIN minimum 0.771), so the observed error-free result reflects the controlled capture conditions of the corpus as much as the matcher, and should not be read as the face false acceptance rate of an uncontrolled deployment.

### 4.5 Evaluation Scope and Limitations

Because the claims of this paper should be read against the evidence that supports them, the scope of the evaluation is stated explicitly.

What was measured. ~~Three~~Four things were measured directly. First, the processing and communication overhead of Section 4.2, over repeated runs of a genuine authentication on a single machine. Second, the score behaviour of the replaced and replacement matchers on a small set of recordings, reported in Section 3.2 as the diagnostic that motivated each replacement. Third, the functional behaviour of the complete scheme, exercised end to end through the browser client against the deployed server. Fourth, face, voice and fused recognition accuracy on the public CREMA-D corpus under the two protocols of Section 4.4.

What was not measured. ~~No recognition-accuracy evaluation was performed. The paper reports no false acceptance rate, no false rejection rate, no equal error rate, and no receiver operating characteristic, and no claim in it should be read as resting on such a metric.~~No accuracy evaluation across days, sessions or capture devices was performed, and none of the challenge factor or of attack resistance; the error rates of Table 6 are the only accuracy figures reported, and they hold for the conditions of that corpus only. The decision thresholds were fixed from observed score separations on the available recordings, which is sufficient to place an operating point but is not a calibration against a target error rate.

Why the evaluation is bounded. The enrolment corpus is small, and it is worth being precise about how small. The stored templates correspond to three distinct human identities. This admits exactly one genuine pairing—two separate recordings of the same person—and three impostor pairings between different people. A corpus of this size cannot support an error-rate estimate with a meaningful confidence interval, and we do not offer one~~from it; the error rates reported are measured on CREMA-D instead~~. Two enrolments in the corpus are also thin, yielding only two frames containing a detectable face, which is a realistic failure mode of unconstrained capture and one that a larger study should characterise rather than exclude.

A consequence of the storage design. The scheme's template-only storage, described in Section 3.3 as a privacy property, has a methodological cost that should be acknowledged: because enrolment recordings are destroyed by design, the measurements taken from them cannot be recomputed later from the retained data. Reproducing them requires re-collecting the recordings. A study intending to publish accuracy results should therefore retain a separately consented evaluation corpus outside the production store, rather than relying on the deployment's own enrolments.

Reproducing the ~~missing~~cross-session evaluation. The cross-session accuracy study absent from this paper is automated rather than merely deferred; the same harness produced the CREMA-D results of Section 4.4. The implementation ships an evaluation harness that enumerates a corpus, extracts one template per recording using the deployed extraction path, verifies that no two recordings produce an identical template, scores every genuine and impostor pair with the deployed matchers, and emits false-acceptance and false-rejection curves, an equal error rate, and detection-error-tradeoff plots. Genuine pairs are formed only between different sessions of the same participant, never a recording against itself. The harness refuses to emit metrics from a corpus that cannot support them~~, which is why no numbers are reported here~~. Running it across sessions requires participant recordings that do not presently exist: at minimum five participants, and at least two separate sessions each, so that within-person variation across sessions is represented rather than assumed. A corpus of twenty to fifty participants with two or three sessions apiece would place the resulting rates on a footing comparable with the schemes surveyed in Section II.

Limits of the CREMA-D evaluation. The error rates of Table 6 are bounded by the corpus that produced them. Every clip of an actor was recorded in a single studio session, with the same recording device and environment, under controlled lighting, framing and acoustics; no protocol here therefore varies the day, the session or the capture device, and no cross-device or cross-session robustness claim is made. The emotions of the SECONDARY protocol are acted rather than spontaneous. The clips are short (median about 2.3 s of audio), which limits the speech available to the speaker embedding. Because face capture is the most tightly controlled of these conditions, the face results in particular are likely optimistic relative to deployment on user-owned webcams and phones. Two neutral clips are absent from the MAIN protocol: one sentence is missing from the release for each of five actors, and the clip 1076_MTI_NEU is truncated to 0.07 s in the release and was excluded because it carries too little audio for a speaker embedding. These results are reported as accuracy under controlled conditions and are not a substitute for the cross-session evaluation described above.

Collecting the corpus without a second protocol. The template-only storage that gives the scheme its privacy property also erases, by design, the very recordings an accuracy study needs, since each recording is reduced to a template and discarded. To avoid a separate hand-managed collection step, the implementation provides an optional, off-by-default capture mode. When it is enabled, a participant using the application in the ordinary way—registering once and then logging in—has each uploaded recording additionally retained under the naming convention the harness consumes, ~~with the registration providing one session and each login another, so that the different-session recordings required for genuine pairs arise from normal use rather than from a staged protocol.~~with the session number set by the operator for each recording session and the issued challenge code carried in each clip's name, so that several logins per session, the different-session recordings required for genuine pairs, and the known spoken content required for challenge and attack evaluation all arise from normal use (Section 4.3). Because retention reverses the guarantee shown to the user, the mode is gated on per-upload consent: the capture page displays an explicit retention notice, retention is opt-in, and the server retains a recording only when consent accompanied that specific upload, so enabling the mode never silently retains anyone who declined. Retained recordings are named by the same keyed hash used for templates, so a leak of the corpus listing discloses no identifiers; the recordings themselves remain identifying by content and must be handled under the participants' consent,

and the mode is never enabled in a deployment.

Key rotation is an unmet operational requirement. The three keys of Section 3.3 are separated by domain and are required to be supplied independently in production, but rotating any of them is not automated and no rotation tooling is provided. The consequences differ per domain and should be planned for before deployment. Replacing $k_{\text{bio}}$ invalidates every stored template twice over: the ciphertexts no longer authenticate under the new key, and the pseudonymous names, being keyed hashes under the same key, no longer resolve. Restoring service therefore requires decrypting each template under the retiring key and re-writing it under the new one at its newly derived name—or, if the retiring key is unavailable, re-enrolling every user, since the recordings the templates came from were destroyed by design. Replacing $k_{\text{pii}}$ requires re-encrypting the stored contact fields and recomputing the email index, without which duplicate-registration checking silently stops matching existing accounts. Replacing $k_{\text{sig}}$ is the mildest case: outstanding sessions and enrolment tokens become invalid and their holders must authenticate again, but no stored data is affected. Nothing in the current implementation performs these migrations, and a deployment that changes a key without one will fail closed—rejecting logins rather than admitting them—which is the correct failure direction but is an outage. Providing an online re-keying path, ideally with a key identifier stored alongside each record so that two key generations can coexist during a migration, is left as future work.

What this means for the comparison in Table 7. Several schemes discussed in Section II report equal error rates on established datasets. No comparison against those figures is made or implied here, since ~~the corresponding quantity has not been measured for this scheme~~the error rates of this scheme were measured on a different corpus and protocol (Section 4.4) and are not directly comparable with them. The comparison offered is the framework comparison of Table 7, which is analytic in nature, and the contribution claimed is one of architecture, storage design and security mechanism rather than one of recognition accuracy.

### 4.6 Analysis of the proposed scheme

We have used the Bonneau et al. framework [11] to analyse our proposed scheme. This comparison is done to access our scheme in terms of usability, deployability and security in comparison to existing authentication schemes. We have included Uname-Passwd in our comparison as it is the most easy form of authentication and preferred by normal users. Hardware token based schemes like Yubikey U2F and FIDO2 are being compared because they offer more security although they have overhead of being carried everytime and costly. Xie et al.'s CamAuth, a two factor authentication scheme which prevents various attacks Like MITM and phishing attacks and considered secure web authentication scheme is also considered for comparison. [15] is a MFA scheme included to compare our scheme's benefits against MFA schemes. Next we compare our scheme against other multimodal biometric authentication schemes like [10], [22], [23] already existing in the literature. This is described in the table 7 given below:

## 5 Conclusions

This paper proposes a multimodal biometric-based authentication system that enhances usability by allowing parallel acquisition of biometric samples. This scheme relates to a user authentication system based on a dynamic CAPTCHA and a real-time single Video input to develop a multimodal biometric authentication system. Through our research, we have achieved the following key findings:

1) ~~We have found that no proposed scheme involves the parallel acquisition of biometric samples and checking liveliness. We have designed a scheme which provides the same.~~Prior multimodal schemes generally acquire each trait through a dedicated sensor and seldom bind acquisition to a per-session challenge; the proposed scheme instead couples parallel acquisition of multiple biometric samples from a single sensor with a challenge-bound liveness cue, and we have designed and implemented a scheme which provides both.
2) The schemes already present in the literature in the field of multimodal biometrics are costly due to the use of expensive devices, which hinders their applicability by users. Our scheme is cost-effective.

~~These findings provide valuable insights into multimodal biometric authentication schemes and contribute to the existing body of knowledge in several ways. They offer a deeper understanding of the problem and lay the foundation for further advancements and improvements in the future.~~The scheme was assessed along two axes: qualitatively against the Bonneau et al. framework, which situates it with respect to existing usability, deployability and security benefits, and quantitatively through the processing-delay measurements of Section 4.2. Neither axis characterises recognition accuracy, which is treated as a limitation below.
~~Moreover, our research has highlighted the significance of multimodal biometrics and its impact on authentication. By addressing and investigating this aspect, we have made significant progress towards advancing the field and filling the existing research gaps.~~The limitations of this work are set out in full in Section 4.5 and are summarised here. Recognition accuracy is not characterised: no false acceptance, false rejection or equal error rate is reported, and the thresholds in use fix an operating point on a small corpus rather than calibrating against a target error rate. The timing results come from repeated runs of one account on a single machine, and their dominant stage is a model-loading cost that a resident model service would largely remove. The liveness argument rests on the unpredictability of the challenge rather than on an explicit presentation-attack detector. The challenge factor depends on an external speech-to-text service, which places the login audio outside the verifier's trust boundary. Reporting error rates over a multi-subject corpus, adding a presentation-attack detection stage, and substituting an on-premises recogniser are the natural directions for future work. The frame- and audio-extraction stages and the speech-to-text stage, previously shown as implementation screenshots, are described in the text of this section and in Algorithm 8: frames are sampled uniformly across the recording, the audio track is demultiplexed from the same recording, and the login audio is transcribed for challenge validation. The matcher outputs,

| Aspect | Benefits offered | Uname-Passwd | Xie et al. | Abdurrahman et al. | Sivakumar et al. | Hamad et al. | Kim and Hong | Yubikey U2F | FIDO2 | Proposed scheme |
|---|---|---|---|---|---|---|---|---|---|---|
| Usability | Memorywise-effortless | ✗ | ✗ | ❑ | ❑ | ✓ | ✓ | ✗ | ✓ | ✓ |
| | Scalable-for-Users | ✓ | ✗ | ❑ | ✗ | ✓ | ✓ | ❑ | ✓ | ❑ |
| | Nothing-to-Carry | ✓ | ❑ | ✓ | ✓ | ✓ | ✓ | ✗ | ✗ | ✓ |
| | Physically-Effortless | ✓ | ✗ | ✓ | ✗ | ✗ | ✗ | ❑ | ✓ | ❑ |
| | Easy-to-Learn | ✓ | ❑ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| | Efficient-to-Use | ✓ | ❑ | ✓ | ❑ | ✗ | ❑ | ✓ | ✓ | ❑ |
| | Infrequent-Errors | ✓ | ✗ | ✓ | ✓ | ❑ | ✓ | ✓ | ✓ | ✓ |
| | Easy-Recovery-from-Loss | ✓ | ❑ | ✓ | ✓ | ✗ | ✗ | ❑ | ✗ | ✓ |
| Deployability | Accessible | ✓ | ✗ | ✓ | ✗ | ❑ | ❑ | ✓ | ✓ | ❑ |
| | Negligible-Cost-per-User | ✓ | ❑ | ❑ | ✗ | ✗ | ✓ | ✗ | ❑ | ✓ |
| | Server-Compatible | ✓ | ✗ | ❑ | ✓ | ✓ | ✓ | ✗ | ✗ | ✓ |
| | Browser-Compatible | ✓ | ❑ | ✓ | ✓ | ✓ | ✓ | ❑ | ✓ | ✓ |
| | Mature | ✓ | ✗ | ✗ | ✗ | ❑ | ✗ | ✓ | ✓ | ✗ |
| | Non-proprietary | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✗ | ✓ | ✓ |
| Security | Resilient-to-Physical-Observation | ✗ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| | Resilient-to-Targeted-Impersonation | ✗ | ✓ | | ✓ | ✓ | ❑ | ✓ | ✓ | ✓ |
| | Resilient-to-Throttled-Guessing | ✗ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| | Resilient-to-Unthrottled-Guessing | ✗ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| | Resilient-to-Internal-Observation | ✗ | ✗ | ✓ | ✓ | ✓ | ✓ | ❑ | ✓ | ✓ |
| | Resilient-to-Leaks-from-Other-Verifiers | ✓ | ✓ | ✓ | ✗ | ✓ | ✓ | ❑ | ✓ | ✓ |
| | Resilient-to-Phishing | ✗ | ✗ | ✗ | ✓ | ❑ | ❑ | ✓ | ✓ | ✓ |
| | Resilient-to-Theft | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✗ | ✓ |
| | No-trusted-Third-Party | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✗ | ✓ | ~~✓~~✗ |
| | Require-Explicit-Consent | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| | Unlinkable | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ | ✓ |
| | Benefit offered count | 18 | 10 | 18 | 17 | 17 | 18 | 13 | 20 | ~~20~~19 |

TABLE 7: Analysis of the Proposed Scheme where ✓: Benefit offered by the scheme, ❑: Partial benefit offered by the scheme ✗: Benefit not offered by the scheme. The ratings in this table are analytic, following the framework's own methodology; they are reasoned from each scheme's design and are not empirical measurements. In particular the security ratings for the proposed scheme are not backed by a recognition-accuracy study, and the entries that would depend on one are argued from the conjunctive decision rule rather than from measured error rates. The No-trusted-Third-Party rating for the proposed scheme is revised downward: the challenge factor transcribes the spoken utterance through an external speech-to-text service, so the login audio leaves the verifier's trust boundary and a third party is relied upon for the availability and correctness of that factor. Replacing it with an on-premises recogniser would restore the benefit and is identified as future work. A registration acknowledgement email is additionally dispatched through a hosted SMTP provider; it is an auxiliary notification sent on a best-effort basis after an account is created and is not part of the authentication workflow, so it does not bear on this rating, though a self-hosted mail relay would remove even that auxiliary dependency. The Unlinkable rating refers to the biometric template store, whose file names are keyed hashes; it does not assert unlinkability of the separate account database, which is discussed in Section 3.3.

previously shown as terminal listings, are consolidated in Table 8.

TABLE 8: Deployed matcher scores on the available recordings (cosine similarity; a factor is accepted when its score reaches the threshold). A genuine pair is two separate recordings of one subject; an impostor pair is two different subjects. These are the diagnostics of Section 3.2 that motivated each matcher replacement, not an accuracy evaluation; no error rate is claimed from them. They replace the superseded perceptual-hash and MFCC/Euclidean matchers.

| Factor (deployed matcher) | Genuine | Impostor | Thresh. |
|---|---|---|---|
| Face: median per-frame cosine (Alg. 4) | 0.8385 | 0.0928 | $\tau_f$=0.35 |
| Voice: ECAPA-TDNN speaker cosine (Alg. 5) | 0.455 | 0.090 | $\tau_a$=0.30 |

The three algorithms previously given here—a login-and-authentication procedure that cascaded the factors and read the enrolled recording from disk, a frame matcher based on perceptual hashing and Hamming distance, and an audio matcher based on mean pairwise Euclidean distance between MFCC matrices—have been withdrawn. They describe an architecture that is no longer the one implemented: the enrolled reference is a template rather than a recording, the two matchers were replaced for the reasons measured in Section 3.2, and the factors are evaluated concurrently rather than in a cascade. The pseudocode below specifies the deployed system end to end, in the order in which the phases occur. Algorithms 1–3 give the three phases of Section 3.1; Algorithms 4–7 give the per-factor decisions and the fusion rule invoked by Algorithm 3; Algorithm 8 is the extraction procedure shared by enrolment and login.

### 5.1 Frame Extraction and Frame Matching

The remainder of this subsection describes the perceptual-hash matcher as originally specified. It is retained for reference and comparison; the deployed face factor is the embedding matcher of Section 3.2 and Algorithm 4, which replaced it because the measurements reported there showed the perceptual hash false-rejecting a genuine user. ~~OpenCV, short for Open Source Computer Vision Library, is a powerful and widely used library for real-time computer vision applications. We are using OpenCV's cv2.VideoCapture class available in python to extract frames from videos.~~Frames are obtained by uniform temporal sampling of the recording, so that the sampled set spans the whole clip rather than a single burst.

We are calculating $pHash$ of each frame captured from video during frame extraction step. A perceptual hash is a compact digital fingerprint derived from a multimedia file (image, audio, video). Unlike cryptographic hashes (like MD5 or SHA256), it focuses on capturing the perceptual similarity of the content, not the exact data. This means that even if an image is slightly modified (e.g., resized, compressed, brightness adjusted), the perceptual hash remains similar, as long as the overall visual content is preserved. Perceptual hashing algorithms typically involve these steps:

- Preprocessing:The multimedia file might undergo basic transformations (e.g., resizing, color space conversion) to ensure consistency.
- Feature Extraction: The algorithm extracts features that capture the essence of the content. For images, these features include Edges, colors, spatial patterns, textures.
- Hashing Function: The extracted features are fed into a hashing function that generates a compact digest (the perceptual hash). This function is designed to produce similar hashes for perceptually similar content.

$pHash$ is the perceptual hashing algorithm popularly used for images. We calculate hamming distance between the phash calculated by first converting these phashes to binary strings to decide the frame matching result. Hamming Distance compares two binary strings of equal length (like phash outputs). It calculates the number of positions where the corresponding bits differ (mismatches). Lower Hamming distance indicates higher similarity between the phashes.

TABLE 9: NOTATIONS AND ABBREVIATIONS

| Notation | Description |
|---|---|
| $Uname$ | Username |
| $V_r$ | Transient video captured during registration (destroyed after extraction) |
| $V_l$ | Video captured during login phase |
| $F_l$ | Frames extracted from login video |
| $A_l$ | Audio demultiplexed from the login recording |
| $P_1, P_2$ | Perceptual Hash value (original design) |
| $MFCC$ | Mel-frequency Cepstral Coefficients (original design) |
| $pHash$ | Perceptual Hashing Algorithm for images (original design) |
| $e_r^f$, $e_{l,i}^f$ | Enrolled face embedding; $i$-th login frame embedding |
| $e_r^a$, $e_l^a$ | Enrolled and login speaker embeddings |
| $\tau_f$, $\tau_a$ | Face and voice acceptance thresholds |
| $b_f, b_a, b_c$ | Face, voice and challenge factor decisions |
| $D$ | Fused authentication decision |
| $C, \mathcal{N}(\cdot)$ | Issued CAPTCHA; normalization map |
| $T(A_l)$ | Ranked transcription hypotheses for $A_l$ |
| $T_r$, $T_l$ | Enrolled template; login template |
| $E$, $\sigma$ | Enrolment token; session token |
| $k_{\text{sig}}$ | Token-signing key (sessions, enrolment) |
| $k_{\text{bio}}$ | Biometric template key (AES-256-GCM, HMAC names) |
| $k_{\text{pii}}$ | Account-PII key (AES-256-GCM, email index) |
| $\mathcal{H}_k(\cdot)$ | Keyed hash (HMAC) under key $k$ |
| $\mathcal{N}_e(\cdot)$ | Email normalization (trim, lowercase) |

### 5.2 Audio Extraction and Audio Matching

We are using ~~FFMPEG frame work to extract frames from~~stream demultiplexing to extract the audio track from the video captured during registration and login phase. The audio track is demultiplexed without re-encoding where possible. Two points differ from the original description. First, no registration audio is demultiplexed at login: the enrolled voice reference is the speaker embedding computed once at enrolment, so only the login recording is processed. Second, the demultiplexed audio is written to a private temporary location that is destroyed when the attempt resolves, rather than to a persistent per-user file.

The remainder of this subsection describes the MFCC matcher as originally specified. It is retained for reference and comparison; the deployed voice factor is the speaker-embedding matcher of Section 3.2 and Algorithm 5, which replaced it because the measurements reported there showed the MFCC statistic failing to separate speakers at any threshold.

For audio matching, we are using Librosa library available in python. It is a versatile tool for working with audio data

Algorithm 1 User Registration / Enrolment

Input: identifier $u$; email address $m$; optional avatar; live recording capability at the client
Output: an encrypted template stored under $\mathcal{H}_{k_{\text{bio}}}(u)$, or a rejection

Phase 1 — account creation (first request)

client submits $(u, m, \text{avatar})$ to the server
if $u$ does not match the permitted identifier character class then reject
if $m$ is empty then reject; idx $\leftarrow \mathcal{H}_{k_{\text{pii}}}(\mathcal{N}_e(m))$ ▷ non-emptiness is the only check on the address; it is matched through its index, never by comparing stored addresses
$a_u \leftarrow$ account holding $u$; $a_m \leftarrow$ account holding idx
if $a_u$ or $a_m$ holds a stored template then reject ▷ an enrolment is never displaced
delete $a_u$ and $a_m$ if present ▷ both conflicts are resolved before either deletion, so a request that will be rejected destroys nothing; an account with no template was never bound to any biometrics, so its identifier is released
create the account record for $(u, \text{idx}, m, \text{avatar})$ by SealAccount ▷ Algorithm 9: identifier readable, contact fields under $k_{\text{pii}}$
$E \leftarrow \text{Sign}_{k_{\text{sig}}}(\{\text{username}{=}u,\ \text{purpose}{=}\text{enrol}\},\ \text{ttl}{=}10\ \text{min})$
▷ the token carries the identifier and the purpose and nothing else—no account identifier, no nonce, and no server-side record of issuance—so it is a bearer credential that any holder may present until it expires
return $E$ to the client

Phase 2 — enrolment (second request)

the client renders a challenge locally; the user records $V_r$ while speaking it
▷ this registration challenge is generated at the client and is never verified: it elicits natural speech for the voice template and is not an authentication factor
client uploads $V_r$, presenting $E$ as a bearer token
if $E$ fails to verify under $k_{\text{sig}}$, or its purpose is not enrolment, or it has expired, or its identifier claim is malformed then reject; otherwise $u' \leftarrow$ the identifier claim of $E$
▷ a session token is refused here because its purpose claim differs, so a stolen session cannot re-key an account
if the uploaded filename does not match the expected pattern then reject ▷ the filename is shape-checked only; the enrolled identity is $u'$, taken from the verified token and never from the filename
$a \leftarrow$ the account whose identifier is $u'$
▷ the lookup is by identifier alone, because $E$ names no account instance: an account created after $E$ was issued, but holding the same identifier, satisfies it
if $a$ does not exist then reject ▷ $E$ outlives an account that was rolled back; no template is stored for an identifier that no account holds
if a template is already stored under $\mathcal{H}_{k_{\text{bio}}}(u')$ then reject
▷ an enrolment is final. $E$ is not consumed by use and stays valid for the remainder of its ten minutes, so it is this check, rather than single-use semantics, that prevents a valid token from replacing a stored template
if evaluation capture is enabled and this upload carried consent then retain a copy of $V_r$ ▷ off by default; when active it suspends the storage property asserted below, and is used only for consented corpus collection (Section 4.5)
write $V_r$ into a private working directory $W$
$T_r \leftarrow \text{ExtractTemplate}(V_r)$ ▷ Algorithm 8, run as a subprocess under a timeout; a timeout counts as failure
if $T_r = \text{failure}$ then ▷ no usable face, unreadable recording, or no usable audio
    destroy $W$; delete the account $a$ ▷ the rollback is itself conditioned on no template being present, and a failure to delete is logged while the rejection is still returned
    return rejection ▷ fail closed: no template is stored, so no account holds an unusable reference
end if
attempt $c \leftarrow \text{Enc}^{\text{AES-256-GCM}}_{k_{\text{bio}}}(T_r)$ and write $c$ under the pseudonymous name $\mathcal{H}_{k_{\text{bio}}}(u')$
▷ the biometric key, never the token-signing key; the keyed name keeps every plaintext identifier out of the template store
destroy $W$, and with it $V_r$ and every plaintext copy of $T_r$ ▷ performed whatever the outcome of the previous step: template-only storage, the recording is never persisted
if the storage attempt failed then
    return failure, leaving $a$ in place ▷ this path performs no rollback, unlike an extraction failure: the account remains with no template and is released by step 6 of a later registration
end if
return registration successful
▷ $E$ is not invalidated here and remains valid until it expires; a further registration for $u'$ is now refused at step 5, because the account holds a stored template

**Algorithm 2** Login and Challenge Issuance

Input: identifier $u$ submitted at the client
Output: a fresh single-use challenge bound to $u$, and an uploaded login recording $V_l$

if $u$ does not match the permitted identifier character class then reject
$C \leftarrow$ five symbols drawn uniformly at random from the challenge alphabet $\Sigma$ ▷ $\Sigma$ is the five-digit decimal alphabet of Section 3.3
bind and store $(u, C, \text{expiry} = \text{now} + 5 \text{ minutes})$ in the server-side challenge store
render $C$ as an image and transmit only the rendered image to the client
▷ the expected string never leaves the server; a client that knew it could satisfy the factor without a live utterance
the user records $V_l$ while speaking the displayed challenge
client uploads $V_l$ under a filename that carries the identifier
if the uploaded filename does not match the expected pattern then reject; otherwise $u' \leftarrow$ the identifier embedded in that filename
▷ this endpoint, unlike enrolment (Algorithm 1), has no token with which to bind the upload: the caller has not authenticated and is precisely in the act of attempting to, so the account whose recording slot is written is named by the client-supplied filename. Binding to a live attempt is supplied by the challenge test below rather than by a credential
if no issued, unexpired challenge exists for $u'$ then reject the upload ▷ a recording cannot be submitted outside a live login attempt; the challenge is checked here but not yet consumed
if evaluation capture is enabled and this upload carried consent then retain a copy of $V_l$ ▷ off by default; when active it suspends the transience asserted below, and is used only for consented corpus collection (Section 4.5)
store $V_l$ encrypted under $k_{\text{bio}}$ in a transient location ▷ two independent branches of Algorithm 3 consume it; it belongs to the biometric domain and is deleted once the attempt resolves
the client requests authentication for $u$ ▷ continues at Algorithm 3

**Algorithm 3** Concurrent Authentication (deployed)

Input: identifier $u$; uploaded login recording $V_l$
Output: session token on success, or a rejection that is identical across the three factors

if no account exists for $u$, or $u$ fails identifier validation, then reject
$C \leftarrow \text{TakeChallenge}(u)$ ▷ retrieves and consumes: single-use, whether or not this attempt succeeds; $C = \perp$ if none was issued or it expired
create a private working area $W$
$T_r \leftarrow \text{Dec}_{k_{\text{bio}}}(\text{store}[\mathcal{H}_{k_{\text{bio}}}(u)])$ into $W$; $V_l \leftarrow \text{Dec}_{k_{\text{bio}}}(\text{transient upload})$ into $W$ ▷ both artefacts belong to the biometric domain and use its key alone
if either decryption or its authentication tag fails then destroy $W$ and reject ▷ fail closed on a missing or tampered artefact
in parallel do
    branch $\mathcal{B}_{\text{bio}}$:
        $T_l \leftarrow \text{ExtractTemplate}(V_l)$ ▷ Algorithm 8; yields $\{e^f_{l,i}\}$ and $e^a_l$
        if $T_l = \text{failure}$ then $b_f \leftarrow 0$; $b_a \leftarrow 0$
        else evaluate concurrently:
            $b_f \leftarrow \text{VerifyFace}(T_r, T_l)$ ▷ Algorithm 4
            $b_a \leftarrow \text{VerifySpeaker}(T_r, T_l)$ ▷ Algorithm 5
    end branch
    branch $\mathcal{B}_{\text{chal}}$:
        $T(A_l) \leftarrow$ the transcription stage of VerifyChallenge$(V_l)$ ▷ Algorithm 6, steps 1–3; depends only on the login audio, so it does not wait on the face or speaker verdict
    end branch
end parallel
wait until $b_f$, $b_a$ and $T(A_l)$ are all available ▷ the conjunction is not evaluated lazily: no factor gates another
$b_c \leftarrow$ the comparison stage of VerifyChallenge$(T(A_l), C)$ ▷ Algorithm 6, steps 4–6: the branch produces the hypotheses concurrently, and the verdict against $C$ is formed once the branches have joined
$D \leftarrow \text{Fuse}(b_f, b_a, b_c)$ ▷ Algorithm 7
record $(b_f, b_a, b_c)$ in the server log only
if $D = 1$ then
    $\sigma \leftarrow \text{Sign}_{k_{\text{sig}}}(\{\text{account, username}{=}u\}, \text{ttl}{=}24\text{ h})$ ▷ session token, signed under the token key and carrying the account reference and identifier; the storage keys play no part here
    $r \leftarrow (\text{granted}, \sigma)$
else
    $r \leftarrow$ denied ▷ a single response, identical whichever factor failed and identical to the response given when decryption failed at step 5; the per-factor outcome is never disclosed. The rejections at step 1, which precede any factor evaluation, are distinguishable from it
end if
destroy $W$ and delete the transient login recording, whatever the outcome
return $r$

in various analysis and processing tasks. We use *librosa.load* to load audio files. It Loads an audio file from disk (specified audio path) into a NumPy array representing the audio waveform. We then compute Mel-frequency cepstral coefficients (MFCCs) from an audio signal. MFCCs are a popular feature representation in audio analysis, capturing the spectral envelope of the sound. One of the parameters in MFCC calculation is n_mfcc which represents the number of MFCC coefficients to compute. We have set this parameter value to 13. This determines the dimensionality of the output feature vector.MFCCs are widely used in various audio processing tasks, including - Speech recognition, Speaker identification. We compute the Euclidean distance between two MFCC vectors to measure their similarity. Smaller distances indicate a higher degree of similarity in the spectral characteristics of the corresponding audio segments.

**Algorithm 4** VerifyFace: face verification

Input: enrolled face reference $e_r^f$ from $T_r$; login frame embeddings $\{e_{l,i}^f\}_{i=1}^n$ from $T_l$
Output: face verdict $b_f$

1: if $e_r^f$ is absent or $n = 0$ then return error ▷ fail closed
2: for $i = 1$ to $n$ do ▷ $n \le 12$: twelve frames are sampled uniformly across the recording
3: $s_i \leftarrow \langle e_r^f, e_{l,i}^f \rangle$ ▷ both vectors are L2-normalized 512-d deep embeddings, so $s_i$ is a cosine similarity
4: end for
5: $s \leftarrow \text{median}(s_1, \ldots, s_n)$ ▷ the median, not the mean: a minority of degraded frames (motion blur, partial pose, transient occlusion) cannot move the verdict
6: if $s \ge \tau_f$ then ▷ deployed threshold $\tau_f = 0.35$
7: $b_f \leftarrow 1$
8: else
9: $b_f \leftarrow 0$
10: end if
11: return $b_f$

**Algorithm 5** VerifySpeaker: voice verification

Input: enrolled speaker embedding $e_r^a$ from $T_r$; login speaker embedding $e_l^a$ from $T_l$
Output: speaker verdict $b_a$

▷ both embeddings are stored quantities: the enrolled one was computed once at registration, the login one by Algorithm 8. No registration audio exists on the server to be re-extracted.

1: if either template carries no speaker embedding then return error ▷ a legacy template cannot be scored; re-enrolment is required
2: $e_r^a \leftarrow e_r^a / \|e_r^a\|$; $e_l^a \leftarrow e_l^a / \|e_l^a\|$
3: $s \leftarrow \langle e_r^a, e_l^a \rangle$ ▷ cosine similarity of two 192-d speaker embeddings
4: if $s \ge \tau_a$ then ▷ deployed threshold $\tau_a = 0.30$
5: $b_a \leftarrow 1$
6: else
7: $b_a \leftarrow 0$
8: end if
9: return $b_a$

**Algorithm 6** VerifyChallenge: spoken-challenge verification

Input: login recording $V_l$; challenge $C$ retrieved and consumed by Algorithm 3
Output: challenge verdict $b_c$

1: $A_l \leftarrow$ audio track demultiplexed from $V_l$
2: $T(A_l) \leftarrow$ ranked transcription hypotheses returned by the speech-to-text stage
3: if demultiplexing or transcription failed then $T(A_l) \leftarrow \emptyset$
4: if $C = \perp$ or $T(A_l) = \emptyset$ then return $b_c \leftarrow 0$ ▷ fail closed when no challenge was issued for this identifier or it expired. The test is applied here rather than before step 1: the transcription stage runs on the login audio regardless, so an attempt carrying no live challenge performs the same work as one that does and is rejected on the same verdict
5: $b_c \leftarrow \mathbb{I}\big[\exists\, t \in T(A_l) : \mathcal{N}(t) = \mathcal{N}(C)\big]$ ▷ equation (3) ▷ any hypothesis may carry the correct reading: the top-ranked alternative for a spoken digit string is frequently a sound-alike word. $\mathcal{N}(\cdot)$ normalizes case and separators and maps spelled-out number words to numerals, so a correct utterance is not rejected for orthographic reasons.
6: return $b_c$

**Algorithm 7** Fuse: decision-level AND fusion

Input: face verdict $b_f$, speaker verdict $b_a$, challenge verdict $b_c$, each in $\{0, 1\}$
Output: fused decision $D$

1: $D \leftarrow b_f \wedge b_a \wedge b_c$ ▷ equation (4)
2: return $D$ ▷ $D = 1$, and access is granted, only when $b_f = b_a = b_c = 1$; $D = 0$ otherwise. The rule is conjunctive by design: the compromise or failure of any single factor is sufficient to deny authentication, so no one modality can produce a positive decision on its own. The caller returns one rejection response for every $D = 0$ case, so which factor was zero is never disclosed to the client.

## References


[1] "Number of internet users worldwide 2022," https://www.statista.com/statistics/273018/number-of-internet-users-worldwide/, accessed: 2023-02-03.

[2] A. Badhib, S. Alshehri, and A. Cherif, "A robust device-to-device continuous authentication protocol for the internet of things," IEEE Access, vol. 9, pp. 124 768–124 792, 2021.

[3] 2022 state of passwordless security. Accessed: 2023-05-10. [Online]. Available: https://get.hypr.com/2022-state-of-passwordless-security

[4] Icmr data leak. Accessed: 2023-11-16. [Online]. Available: https://economictimes.indiatimes.com/tech/technology/opposition-security-experts-seek-answers-on-icmr-data-leak/articleshow/104865920.cms

[5] A. R. Ignacio Velasquez, Angelica Caro, "Authentication schemes and methods: A systematic literature review," Information and Software Technology, vol. 94, pp. 30–37, 2018.

[6] P. Gupta and P. Gupta, "An accurate finger vein based verification system," Digital Signal Processing, vol. 38, pp. 43–52, 2017.

[7] Y.-H. Khoo, B.-M. Goi, T.-Y. Chai, Y.-L. Lai, and Z. Jin, "Multimodal biometrics system using feature-level fusion of iris and fingerprint," Proceedings of the 2nd International Conference on Advances in Image Processing, p. 6–10, 2018.

[8] R. Das, E. Piciucco, E. Maiorana, and P. Campisi, "Convolutional neural network for finger-vein-based biometric identification," IEEE Transactions on Information Forensics and Security, vol. 14, no. 2, pp. 360–373, 2018.

[9] D. T. P. N. Harini, "2cauth: A new two factor authentication scheme using qr-code," International Journal of Engineering and Technology, vol. 5, no. 2, pp. 1087–1094, 2013.

[10] P. Sivakumar, B. R. Rathnam, S. Divakar, M. A. Teja, and R. R. Prasad, "A secure and compact multimodal biometric authentication scheme using deep hashing," pp. 27–31, 2021.

[11] J. Bonneau, C. Herley, P. C. Van Oorschot, and F. Stajano, "The quest to replace passwords: A framework for comparative evaluation of web authentication schemes," 2012 IEEE symposium on security and privacy, pp. 553–567, 2012.

[12] G. Varshney, M. Misra, and P. Atrey, "Secure authentication scheme to thwart rt mitm, cr mitm and malicious browser extension based phishing attacks," Journal of Information Security and Applications, vol. 42, pp. 1–17, 2018.

[13] K. Y. J.K. Lee, S.R. Ryu, "Fingerprint-based remote user authentication scheme using smart cards," Electronics Letters, vol. 38, no. 12, 2002.

[14] D. R. K. M. Binitha Ann Scaria, "Enhanced e-commerce application security using three-factor authentication," Proceedings of

**Algorithm 8** ExtractTemplate: shared extraction procedure

Input: recording $V$
Output: template $T = \{e^f, \{e_i^f\}, e^a\}$, or failure

if the container reports a frame count then
    sample $m = 12$ frames uniformly across $V$
else
    read $V$ sequentially, retaining every fifth frame, until 12 embeddings have been obtained
        ▷ browser-produced containers frequently report no frame count, so uniform sampling has no index range to span; the stride keeps the retained frames from being one contiguous burst
end if
for each retained frame do
    detect faces; if several are present, retain the largest
    $e_i^f \leftarrow$ L2-normalized 512-d deep face embedding of the retained face
end for
if no frame yielded a face then
    return failure  ▷ fail closed: at enrolment no template is stored, at login the biometric verdicts are 0
end if
$e^f \leftarrow \mathrm{normalize}\big(\mathrm{mean}_i\, e_i^f\big)$  ▷ used as the enrolled face reference; at login the per-frame set $\{e_i^f\}$ is what Algorithm 4 scores
demultiplex the audio track of $V$ and resample to 16 kHz mono
if audio shorter than one second then
    return failure
end if
$e^a \leftarrow \mathrm{normalize}\big(\text{speaker-embedding network}(\text{audio})\big)$  ▷ 192-d ECAPA-TDNN embedding
return $T$

**Algorithm 9** SealAccount: account-record storage

Input: identifier $u$; email address $m$; optional profile fields $p = (\text{first}, \text{last}, \text{mobile}, \text{address}, \text{avatar})$
Output: an account record in which only $u$ is readable

store $u$ in plaintext  ▷ the login lookup key; the client submits it on every request, so sealing it would conceal nothing and would put a blind index on the authentication path
idx $\leftarrow \mathcal{H}_{k_{\text{pii}}}\big(\mathcal{N}_e(m)\big)$  ▷ keyed index over the normalized address: deterministic, so duplicate registration is still detected; not invertible, so no stored address is read to detect it
store idx, and enforce uniqueness on it rather than on the address  ▷ ciphertext cannot carry uniqueness: a random IV makes two equal addresses differ byte for byte
store $\mathrm{Enc}_{k_{\text{pii}}}^{\text{AES-256-GCM}}(m)$
for each supplied field $f \in p$ do
    store $\mathrm{Enc}_{k_{\text{pii}}}^{\text{AES-256-GCM}}(f)$  ▷ account domain key throughout; $k_{\text{bio}}$ and $k_{\text{sig}}$ are never used here
end for
    ▷ this record is held in the account database, which contains no template and no template name; the template store (Algorithm 1) correspondingly contains no plaintext identifier
    ▷ on read, the sealed fields are opened and returned, idx is withheld from the client, and a field failing its authentication tag rejects the read rather than returning a partial record. The profile endpoint of the prototype is not access-controlled: it opens the record for any caller naming the identifier, so the protection this procedure provides is confidentiality against a compromise of the database itself, not an access-control property of the running service


the Second International Conference on Intelligent Computing and Control Systems (ICICCS 2018), pp. 1588–1591, 2018.

[15] J. M. Usman Alhaji Abdurrahman, Mustafa Kaiiali, "A new mobile-based multi-factor authentication scheme using pre-shared number, gps location and time stamp," 2021 International Conference on Computer Communications and Networks (ICCCN), pp. 1–7, 2021.

[16] M. A. Emanuela Marasco, "Fingerpin: An authentication mechanism integrating fingerprints and personal identification numbers," Computer Vision and Image Processing: 5th International Conference, CVIP 2020, Prayagraj, India,Revised Selected Papers, Part I 5, pp. 500–511, 2021.

[17] V. V. R. P. A. V. S. S. S. Emanuela Marasco, Massimiliano Albanese, "Biometric multi-factor authentication: On the usability ofthe fingerpin scheme," Security and Privacy, vol. 6, no. 1, 2023.

[18] M.-S. H. Chun-Ta Li, "An efficient biometrics-based remote user authentication scheme using smart cards," Journal of Network and computer applications, vol. 33, no. 1, pp. 1–5, 2010.

[19] A. K. Das, "Analysis and improvement on an efficient biometric-based remote user authentication scheme using smart cards," IET Information Security, vol. 5, no. 3, pp. 145–151, 2011.

[20] C.-W. H. Cheng-Chi Lee, "A secure biometric-based remote user authentication with key agreement scheme using extended chaotic maps," Nonlinear Dynamics, vol. 71, pp. 201–211, 2013.

[21] D. S. D. Jagadiswary, "Biometric authentication using fused multimodal biometric," International Conference on Computational Modeling and Security (CMS 2016), vol. 85, pp. 109–116, 2016.

[22] M. Hammad, Y. Liu, and K. Wang, "Multimodal biometric authentication systems using convolution neural network based on different level fusion of ecg and fingerprint," IEEE Access, vol. 7, pp. 26 527–26 542, 2018.

[23] D.-S. Kim and K.-S. Hong, "Multimodal biometric authentication using teeth image and voice in mobile environment," IEEE Transactions on Consumer Electronics, vol. 54, no. 4, pp. 1790–1797, 2008.

[24] F. Ahamed, F. Farid, B. Suleiman, Z. Jan, L. A. Wahsheh, and S. Shahrestani, "An intelligent multimodal biometric authentication model for personalised healthcare services," Future Internet, vol. 14, no. 8, p. 222, 2022.

[25] S. M. R. Bagwan, S. Kumar, and S. B.Thigale, "Face, iris, and fingerprint based robust biometric authentication system," pp. 1–8, 2023.

[26] K. Jha, A. Jain, and S. Srivastava, "Feature-level fusion of face and speech based multimodal biometric attendance system with liveness detection," AIP Advances, vol. 14, no. 11, p. 115007, 2024. [Online]. Available: https://doi.org/10.1063/5.0234430

[27] A. Sureshkumar, M. Sathyamoorthy, R. K. Dhanaraj, S. Aanjanadevi, and V. Palanisamy, "Secure facial biometric authentication in smart cities using multimodal methodology," Scientific Reports, vol. 15, p. 44839, 2025. [Online]. Available: https://doi.org/10.1038/s41598-025-29048-5

[28] K. Jha, A. Jain, and S. Srivastava, "Multimodal biometric authentication system leveraging optimally trained ensemble classifier using feature-level fusion," Technology and Health Care, 2025. [Online]. Available: https://doi.org/10.1177/09287329251363424

[29] K. W. Chen et al., "Two-step authentication: Multi-biometric system using voice and facial recognition," 2026, also in IET Conference Proceedings, doi:10.1049/icp.2024.4141. [Online]. Available: https://arxiv.org/abs/2601.06218

[30] K. Jha, A. Jain, and S. Srivastava, "A challenge-response based authentication approach for multimodal biometric system using deep learning techniques," Scalable Computing: Practice

and Experience, vol. 26, no. 5, 2025. [Online]. Available: https://doi.org/10.12694/scpe.v26i5.4733
[31] B. Alharbi and H. S. Alshanbari, "Face-voice based multimodal biometric authentication system via FaceNet and GMM," PeerJ Computer Science, vol. 9, p. e1468, 2023. [Online]. Available: https://doi.org/10.7717/peerj-cs.1468
[32] H. Mandalapu, P. N. A. Reddy, R. Ramachandra, K. S. Rao, P. Mitra, S. R. M. Prasanna, and C. Busch, "Audio-visual biometric recognition and presentation attack detection: A comprehensive survey," IEEE Access, vol. 9, pp. 37 431–37 455, 2021. [Online]. Available: https://doi.org/10.1109/ACCESS.2021.3063031
[33] N. Jiang, B. Sun, T. Sim, and J. Han, "Can I hear your face? Pervasive attack on voice authentication systems with a single face image," in 33rd USENIX Security Symposium (USENIX Security 24). USENIX Association, 2024, pp. 1045–1062. [Online]. Available: https://www.usenix.org/conference/usenixsecurity24/presentation/jiang-nan
[34] C. Rathgeb, J. Kolberg, A. Uhl, and C. Busch, "Deep learning in the field of biometric template protection: An overview," 2023. [Online]. Available: https://arxiv.org/abs/2303.02715
[35] G. Zhao, Q. Jiang, D. Wang, X. Ma, and X. Li, "Deep hashing based cancelable multi-biometric template protection," IEEE Transactions on Dependable and Secure Computing, vol. 21, no. 4, pp. 3751–3767, 2023. [Online]. Available: https://ieeexplore.ieee.org/document/10330618/
[36] J. Deng, J. Guo, N. Xue, and S. Zafeiriou, "Arcface: Additive angular margin loss for deep face recognition," in Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR), 2019, pp. 4690–4699.
[37] B. Desplanques, J. Thienpondt, and K. Demuynck, "ECAPA-TDNN: Emphasized channel attention, propagation and aggregation in TDNN based speaker verification," in Proc. Interspeech 2020, 2020, pp. 3830–3834.
[38] Ffmpeg. Accessed: 2023-06-07. [Online]. Available: https://www.ffmpeg.org/
[39] Speechrecognition 3.10.0. Accessed: 2023-06-07. [Online]. Available: https://pypi.org/project/SpeechRecognition/
[40] librosa. Accessed: 2023-06-07. [Online]. Available: https://librosa.org/doc/latest/index.html
[41] svg-captcha. Accessed: 2023-06-07. [Online]. Available: https://www.npmjs.com/package/svg-captcha
[42] H. Cao, D. G. Cooper, M. K. Keutmann, R. C. Gur, A. Nenkova, and R. Verma, "CREMA-D: Crowd-sourced emotional multimodal actors dataset," IEEE Transactions on Affective Computing, vol. 5, no. 4, pp. 377–390, 2014.